Threat Intelligence

Threat evolution in Q2 2020

July 2020

group-ib.com

Contents

INTRODUCTION **3**

EXECUTIVE SUMMARY **4**

Targeted attacks on the financial sector 4

Financial threats 4

Ransomware 5

Exploits 6

Threats to the government sector 6

Data leaks 8

FORECASTS FOR Q3 2020 **10**

ADVANCED THREATS IN THE FINANCIAL SECTOR **11**

FINANCIAL THREATS **16**

Malware for Android 17

Threats and malware for PC 23

Attacks on ATMs and POS terminals 32

RANSOMWARE **34**

EXPLOITS **42**

STATE-SPONSORED APTS **44**

Chafer 64

OilRig 65

Operation In(ter)ception 67

DATA LEAKS **70**

Introduction

Every quarter Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends, and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on Europe, Russia, the US, Canada, and Australia. This document also provides a comprehensive description of threats to governments, including targeted attacks supported by governments and significant data leaks.

To collect data and inform our clients, we analyze various botnets and malware while conducting incident response, monitoring underground forums and accumulating information on new trends, threats, and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages, and announcements on the dark web, as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Executive summary

Targeted attacks on the financial sector

Q2 2020 saw the following APT campaigns against financial organizations:

- Lazarus (North Korea) upgraded their tools: the group extended the commands of the PowerTask Trojan and added a macOS version of Dacls RAT (remote access Trojan). In addition, the hackers carried out new attacks to steal cryptocurrency using programs called Coin Go Trade and Kupay Wallet. They also attacked Korea Investment & Securities Co., Ltd., a financial company, through spear phishing.
- Leery Turtle hackers, active since 2017, managed to remain undetected; they have been attacking cryptocurrency exchange companies globally.
- FIN6 has been attacking financial, construction and trade organizations in the United States and Europe using TrickBot, Anchor, and more_eggs.
- FIN7 is believed to be using a new VBS loader whose first samples are dated March 2020.
- May saw the discovery of an email campaign involving more_eggs malware; either FIN6 or Cobalt may be behind it.

Financial threats

- We have been tracking numerous mailouts to banks containing the Zloader loader since April. The emails usually contain an Excel file with a macro, which loads Zloader (aka Terdot, DeLoader, and Sphinx). Zloader can load other malware, such as banking Trojans Silent Night, Gozi, and Trickbot.
- Group-IB specialists discovered the sale of a new Android banking Trojan called Alien bot in the underground. The Trojan's developer is a threat actor with the nickname -ring0-. A description of the malware was obtained during a conversation with the threat actor.
- A new service for creating web fakes for mobile devices that can be used with various Trojans, such as Cerberus, Anubis, and Alien, was discovered. The service is offered by a threat actor with the nickname InTheBox. They already have web fakes targeting various banks worldwide.
- We have also observed the activity of Anubis, an Android banking Trojan. It was involved in attacks against users in Malaysia, Turkey, and Russia.
- Group-IB specialists analyzed an Android banking Trojan called OperadorMIB, which attacks users in Italy, Brazil, Chile, Mexico, Portugal, and Spain.
- The updated Android banking Trojan Cerberus v.2 was put up for rent on an underground forum.
- FlexNet has been one of the most dangerous banking Trojan for Russian Android users; however, we also started observing Anubis attacks against Russian users. At the moment, we are analyzing this threat in more detail.
- Group-IB specialists continue to observe high activity of JS sniffers for bank cards (Inter, Poter, CoffeeMokko, and PostEval). In addition, a new sniffer called mr.SNIFFA emerged.
- Group-IB specialists have discovered a threat group called Clownz, which has carried out attacks against financial organizations since 2014. The primary target is the United States. This information is not subject to distribution.
- Attacks against legal entities in post-Soviet countries involving RTM continue.
- Group-IB specialists analyzed a new version of IcedID (21st one), in which configuration files are hidden in PNG images. In earlier versions (e.g. version 12), the PNG file only contained the main module. The Trojan's main targets are US banks.

- Group-IB specialists analyzed Gozi v3, a new version of the banking Trojan Gozi/ISFB. It has the same functionality as that of Gozi 2.X versions. The difference is in its modular architecture. The targets include Australian and Italian banks.
- Trickbot was fitted with a new propagation module (nworm); banks in North America, Europe, and Japan were targeted.
- Group-IB specialists discovered a threat group called ShadowSinger, which attacked the mobile devices of users in Malaysia and Vietnam.
- An attack involving the TinyPosh Trojan against Russian companies was discovered in April.
- MagicPos is active among malware for POS terminals. It was used to compromise numerous bank cards in the United States; over 67,000 compromised cards were discovered by Group-IB specialists in their analysis of a group of attackers.
- Group-IB specialists analyzed a series of successful multi-stage phishing attacks against the top managers of more than 150 international organizations from the US, Canada, Germany, the UK, the Netherlands, Hong Kong, Singapore, and other countries. The campaign (which was dubbed PerSwaysion because of its active use of the MS Sway service in one of its stages) has been active since mid-2019.
- In April, a database called SCARFACE-DISCOUNT-SALE with 400,000 cards (US cards made up half of it, the other half were South Korean cards) was put up for sale on Joker's Stash, a card shop.
- In May, databases called IRONY-DISCOUNT-SALE and XYZ-DISCOUNT-SALE with over 600,000 cards in total (most of them being US cards, with 9% belonging to UAE banks) were put up for sale on the same card shop.
- A database called 13.05-SINGAPORE SNIFFED was published on Feshop, a card shop. It contained 10,000 cards, all belonging to banks in Singapore.
- June saw attacks by TA505 against German and Canadian companies.
- The banking Trojan Retefe is still active in Europe, in particular Switzerland and Norway.
- Danabot attacked banks in Australia, Poland, and Germany.
- The banking Trojan Backswap reappeared and has been attacking banks in Spain.
- Ramnit is one of the most active Trojans in Japan and Europe.
- Qbot primarily targeted US banks.
- Specialists at Avira discovered a new ATM Trojan in Brazil. It is called DispCashBR.

Ransomware

Ransomware has truly become the biggest threat: we receive information about major incidents on a daily basis. This report covers them only partially.

- May saw an attack involving the ProLock ransomware against Diebold Nixdorf, an ATM manufacturer. Group-IB specialists established that ProLock operators used two main vectors of initial compromise: the QakBot (Qbot) Trojan and unprotected Remote Desktop Protocol (RDP) servers with weak passwords.
- The REvil threat group (Sodinokibi) attacked a US law firm called Grubman Shire Meiselas & Sacks. In June, the threat actors started an auction for the data of the company Intercard Inc.
- The Snake (Ekans) ransomware was used in June in an attack against Honda; the incident affected networks in Europe and Japan. Snake also attacked the energy company Enel.
- The threat group Maze carried out attacks against the following companies: Bouygues Construction (France), Banco BCR (Costa Rica), Cognizant (USA), ST Engineering (Singapore), MaxLinear Inc (USA), Conduent Inc (USA), M.J. BRUNNER Inc (USA), Columbus Metro Federal

Credit Union (USA), WorldNet Telecommunications (Puerto Rico), Xerox Corporation (USA), LG ELECTRONICS, and Club Fitness (USA).

- In May, the Clop ransomware attacked Technische Werke Ludwigshafen (TWL), a German energy company.
- The threat group Nefilim published information about the companies W&T Offshore, MAS Holding, Arteris SA, Cosan, Aliansce Sonae, Toll Group, Aban Offshore, and Fisher & Paykel.
- The threat group that uses the DoppelPaymer ransomware was also highly active and published data on 24 companies on their blog.

Exploits

- In April, Group-IB specialists discovered a post that advertised the sale of a new 0-day exploit for Internet Explorer for Windows 8-10. The exploit targets two vulnerabilities: remote code execution and sandbox escape. According to the seller, Microsoft has not yet released recommendations on these vulnerabilities.

- An exploit kit made up of two exploits (Silent and Macro combined in one file) was discovered. Silent targets the 1-day vulnerability CVE-2017-11882, which exists in almost all versions of Microsoft Office, while the Macro exploit affects all Microsoft Office versions.

Threats to the government sector

Governments are always going to be under the threat of cyber espionage and in some cases suffer attacks on critical infrastructure. Group-IB specialists perform an independent analysis of such threats and are well-informed about the results of global expert studies. The following APT campaigns against government organisations were detected in Q2 2020:

- Lazarus (North Korea) carried out attacks targeting the arms and heavy industries using spear-phishing emails containing job descriptions and information about COVID-19.
- Attacks by Kimsuky (North Korea) targeted South Korean defense companies and the foreign and security sectors. The group's malicious activities were part of an ongoing campaign called Operation Smoke Screen.
- A new backdoor called Speculoos by APT41 (China) was observed in attacks against Citrix network appliances, which affected the healthcare, higher education, manufacturing, and government industries, as well as technology services in multiple regions around the world, such as North America, South America, and Europe. In addition, the group exploited the 0-day vulnerability CVE-2020-10189 in Zoho ManageEngine Desktop Central.
- A previously unknown hacker group called TwoSail Junk carried out a large-scale watering hole attack against Hong Kong residents, in which multifunctional malware called LightSpy was installed on victims' smartphones.
- Unidentified hackers used a new Trojan called PoetRAT to attack SCADA systems in Azerbaijan.
- The Gamaredon threat group (Russia) continued its attacks against Ukraine and used the COVID-19 topic for spear-phishing emails in Europe. It was observed that the group used a Microsoft Outlook Visual Basic for Applications (VBA) project to attack Microsoft Outlook.
- Gorgon Group hackers (Pakistan) carried out mailouts with a decoy in the form of COVID-19 information, presumably to Canadian targets; it was found that the latest payload was hosted on

GitLab. In addition, the group continued its actions as part of the Aggah campaign and updated its arsenal of RATs and Pastebin accounts.

- APT37 (North Korea) persisted with their attacks and continued using the Konni Trojan and SYSCON/SANNY, along with decoys about COVID-19, academic conferences, nuclear issues, and the Paralympic Games.
- Naikon hacker (China) remained undetected for about five years. The group carried out cyberespionage attacks against government entities in Australia, Indonesia, the Philippines, Vietnam, Thailand, Myanmar, and Brunei using a new Trojan called Aria-body.
- The Patchwork threat group (India) carried out a four-month campaign against government and military organizations in South Asia using a new version of the BackConfig malware.
- Over the past several years, Tropic Trooper (China) has been using the USBferry malware to attack physically isolated networks of Taiwanese and Philippine military organizations, navy agencies, government institutions, military hospitals, and even a national bank. Tropic Trooper is also behind a phishing campaign aimed at collecting data about Vietnamese government officials amid an ongoing territorial dispute between China and Vietnam.
- A cyberespionage campaign against telecommunications and gas companies as well as a government entity in Central Asia took place; the campaign was dubbed Mikroceen and attributed to China.
- APT15 (China) used a new backdoor called Ketrum, which was created through the merger of features in the documented backdoor families Ketrican and Okrum.
- Throughout 2018–2019, a previously unknown group called Chimera attacked companies in Taiwan's superconductor industry.
- SideWinder (India) continued its attacks against Pakistan; the hackers disguised their activity as a COVID-19–related mailing.
- The Charming Kitten threat group (Iran) is suspected of attempting to compromise the servers of the World Health Organization and Donald Trump's presidential campaign.
- Cycldek hackers (China) used a previously unknown tool called USBCulprit; it is designed to steal data from corporate networks and gives threat actors the capability to reach devices that are physically isolated and not directly connected to the Internet.
- Higaisa (South Korea) sent out phishing emails with New Year greetings, COVID-19 information, and other topics.
- DarkHotel (North Korea) attacked Chinese organizations and their offices in other countries using a vulnerability in SangFor VPN. In addition, previously unknown malware called Ramsay was discovered, which can steal data from physically isolated systems.
- An HTTP status-based Trojan used by the Turla group (Russia) since December 2019 in attacks against European government organizations was discovered.
- The Mustang Panda hacker group (China) used the DLL side-loading technique with subsequent installation of the PlugX Trojan against unknown targets.
- Attacks against US utilities by the threat group TA410 (China) were discovered. The attacks had been carried out since July 2019 and involved LookBack and FlowCloud malware.
- Our system for detecting malicious infrastructures identified the C&C servers of the Cobalt Strike post-exploitation framework. The servers are used by the OceanLotus group (Vietnam). In addition, attacks against the Wuhan government and the Chinese Ministry of Emergency Management were detected. Details were revealed about the PhantomLance campaign, targeted at Android users in India, Vietnam, Bangladesh, Indonesia, Nepal, Myanmar, and Malaysia.
- The OilRig threat group (Iran) carried out attacks against telecommunications providers in South Asia. In addition, our system for detecting malicious infrastructures identified multiple malicious domains used by this threat group.

- The MuddyWater threat group (Iran) left a website with open directories; the group used it as a C&C server. Analysis of logs revealed that the victims were located in Pakistan, Turkey, the US, Canada, Spain, Germany, and the UK. Some of the addresses belonged to Iranian Internet service providers, which most likely suggests that the tools were being tested.
- Information was revealed about attacks carried out by the Chafer threat group (Iran) against organizations in Kuwait and Saudi Arabia in 2018.
- A cyberespionage campaign against the aerospace and military industries in Europe and the Middle East was discovered. The campaign was dubbed Operation In(ter)ception.
- Security specialists discovered a campaign by the threat group InvisiMole, targeting the military sector and diplomatic missions in Eastern Europe. The hackers collaborated with other threat actors from the Gamaredon group to penetrate the target network and deliver the advanced InvisiMole Trojan to the targets.
- Information was published about attacks against Russian organizations in 2017. The attacks were carried out by an unidentified threat group, which used the AcidBox malware.
- Unidentified hackers carried out an attack against Australian government entities and private companies. The hackers exploited remote code execution vulnerabilities in Telerik UI as well as vulnerabilities in Microsoft Internet Information Services (IIS), SharePoint 2019 software, and Citrix 2019 software.
- After a lull, APT30 (China) carried out attacks against Malaysia, in which the group used old Trojans, NETEAGLE and BACKSPACE, as well as previously unknown backdoors, RHttpCtrl and RCtrl.

Data leaks

- In May, a leak of 90 GB worth of data (information on 22 million people) that affected the Cyprus-based company Covve was confirmed.
- Early May saw the discovery of an open Elasticsearch database belonging to the Thai telecommunications company Advanced Info Service (AIS). The database contained over 8 million documents.
- In late May, Nippon Telegraph & Telephone (NTT), Japan's largest telecommunications company, reported a data leak. According to the victim company, hackers penetrated its network and later sold data on 621 customers.
- Shiny Hunters hackers published data on 15 million users of Tokopedia, Indonesia's largest online store.
- A hacker with the nickname KingNull made public the database of Daniel's Hosting (DH), one of the biggest hosting services on the Darknet.
- In June, a data breach that occurred at the South African bank Postbank in 2018–2019 was discovered. The bank lost $3.2 million due to the incident and had to reissue 12 million cards, which also entailed considerable expense.
  This data leak is a result of a serious violation of information security principles on the part of the bank. A dishonest employee copied the host master key (HMK) in one of the bank's data centers, which subsequently allowed them to gain access to users' bank accounts and carry out unauthorized transactions. If the HMK had been stored and protected properly, the key would have never fallen into the hands of one person (the secret sharing principle).
- EasyJet reported a data leak that affected about nine million customers and 2,208 bank cards.

- The hospitality company Marriott reported another data leak, which affected 5.2 million records with customers' personal data.
- In June, the computer game Stalker Online was breached, which resulted in over 1 million user passwords being leaked.
- In June, over 20 million records were leaked from the portal of the Department of Household Registration under Taiwan's Ministry of Interior. The leaked data was put up for sale on the Darknet.

Forecasts for Q3 2020

- The threat posed by ransomware has come to the fore. Unfortunately, we expect new attacks against major companies by groups such as REvil, Maze, Nefilim, ProLock, DoppelPaymer, Clop, Snake, NetWalker, and others. As before, criminal groups will cooperate with services for obtaining and selling access to corporate networks.
- The Silence threat group may stop attacking banks and start making money by encrypting data, a method other threat groups have been using lately.
- Attacks by the TA505 group involving its Get2 and SDBot malware will continue.
- Lazarus will carry out attacks against both the government and financial sectors, as well as cryptocurrencies, using its new tools, PowerTask and Dacls RAT.
- Mailouts to banks containing the Zloader malware will continue in Europe.
- We have seen the emergence of new Android malware as well as updates of old versions (Cerberus, Alien Bot, and OperadorMIB). This suggests that the number of attacks on mobile devices of banking customers and thefts will rise.
- Anubis will be one of the most active Android banking Trojans out there; attacks involving it will be seen in various regions: Europe, Asia, and the Americas.
- Bank card sniffers will remain the most relevant threats. Group-IB specialists continue to detect infections on many websites. In addition, the code of the existing sniffers is being improved and new sniffers are put up for sale, it has been observed.
- Mass mailouts with the RTM Trojan affecting Russian-speaking legal entities will continue.
- In the past six months, Trickbot developers have been adding new modules; the malware will continue to be developed. The focus will stay on North American and European banks.
- IcedID will be active in North America.
- Gozi attacks will take place in Australian and Italian banks.
- FlexNet will attack Android users in Russia.
- Trickbot and Ramnit will be a relevant threat for users and banks in Japan.

Advanced threats in the financial sector

333

APT name	Regions attacked	Operation start
Lazarus	Global, South Korea, Singapore, Hong Kong	2018

On April 8, a suspicious application for macOS called TinkaOTP was uploaded to VirusTotal from Hong Kong. The executable file of the malicious bot is located in the directory Contents/Resources/Base.lproj/ and pretends to be a .nib file ("SubMenu.nib") while being a Mac executable. It contains the strings "c_2910.cls" and "k_3872.cls," which are the names of the certificate and private key files, which have been observed observed.

Security specialists identified it as a new variant of Dacls RAT (Remote Access Trojan), which is attributed to the North Korean threat group Lazarus and which has been developed specifically for Mac operating systems. A variant for other platforms was discovered in October 2019.

This Mac RAT has all the six plugins seen in the Linux variant (CMD plugin, File plugin, Process plugin, Test plugin, RP2P plugin, and LogSend plugin) with an additional plugin named SOCKS. This new plugin is used to proxy network traffic from the victim to the C&C (command and control) server.

The app loads all seven plugins at the start of the main loop. Each plugin has its own configuration section in the config file, which will be loaded at the plugin initialization stage.

In addition, the use of an updated version of the PowerTask Trojan was detected. Commands in the new version were renamed and the command **ra** was added, which creates a process under the currently logged-in user by using a publicly available script (http://rzander.azurewebsites.net/create-a-process-asloggedon-user/). In addition, a file called "t.ps1" was detected, which collects network information related to Alliance Access/Entry (SWIFT) processes and outputs data about the system in c:\temp\prt.log. Once the script finishes running, the Trojan sleeps for ten seconds before launching the script again.

Lazarus created yet another cryptocurrency trading program, which installs a backdoor on victim Mac or Windows computers. Analysis of the new scheme revealed that it was very similar to a previous operation involving the creation of a malicious crypto-trading application called AppleJeus as well as JMT Trader and Union Crypto Trade.

This time the programs were called Coin Go Trade and Kupay Wallet. The hackers developed websites where they promoted them (hXXps://coingotrade.com/ и hXXps://kupaywallet.com/).

In addition, the threat actors created Twitter accounts for a bigger audience coverage.

On May 12, 2020, the FBI, the US Department of Defense, and the Cybersecurity and Infrastructure Security Agency of the Department of Homeland Security (DHS CISA) revealed information about three malicious programs attributed to Lazarus.

COPPERHEDGE is a remote access Trojan that can launch arbitrary commands, conduct reconnaissance, and steal data. Six variants of this Trojan have been detected.

TAINTEDSCRIBE is a malicious implant (Trojan) installed on hacked systems to receive and execute commands from threat actors. It uses FakeTLS for session authentication and utilizes a Linear Feedback Shift Register (LFSR) algorithm for encryption. The main executable disguises itself as Microsoft's Narrator.

PEBBLEDASH is another implant, which has the capability to download, upload, delete, and execute files; enable Windows CLI access; create and terminate processes; and so on.

It has been discovered that the code of the published samples is similar to that of the Manuscrypt malware, which has long been used by Lazarus. Most of the indicators are related to 2018–2019 and are already in our notifications.

On May 22, 2020, a spear-phishing campaign against Korea Investment & Securities Co., Ltd took place.

In this attack, 20 HWP, XLSX and JPEG files were attached directly to the email and 9 files were added as large attachments. The attacker attached a number of files and used them to deceive the recipient, inserting the malicious code into a file called "※(창고허득)경기이천율면월포리9980평급18억토목완hwp."

The Hangul file launches a malicious function, controlling a malicious PostScript (EPS) inside. This EPS causes vulnerability CVE-2017-8291 for executing internal code.

The shellcode creates a file named "security.vbs" and accesses the C&C address to download and install additional malicious files.

The additional downloaded files are disguised as PNG images, but are Base64-encoded. After the decoding process, a 32-bit DLL file is created, and based on the file's timestamp, its creation date is May 23, 2020.

The malicious file executes the additional command of the attacker through C&C communication again, and this may lead to exposure to various threats.

Lazarus (also known as Dark Seoul Gang, HIDDEN COBRA, and Guardians of Peace) is a cybercriminal group active since 2007. It has been established that its members are from North Korea.

APT name	Regions attacked	Operation start
Leery Turtle	Global	2017

January 2020 saw the discovery of the group Leery Turtle (aka DangerousPassword) and new details about its activities surfaced in May 2020. Leery Turtle is a threat group active since at least late 2017. It targets cryptocurrency exchange companies globally. The group constantly carries out spear-phishing campaigns to infect its targets with custom-written malware.

Leery Turtle does not focus on any particular region and targets businesses worldwide. The group mostly targets technical and executive roles.

In their operations, Leery Turtle employs extensive reconnaissance tactics. To determine vulnerable entry points, it sends decoy emails with non-malicious attachments and monitors which of its targets tend to open and download them. Evidence also suggests that Leery Turtle selects and profiles its targets at an advanced level to the details of their private life.

Attacks imitate commonly used file storage services like Google Drive, Microsoft OneDrive, etc. This mimicking behavior is also observed in their choice of domains. The hackers also use email spoofing techniques to make emails appear as coming from a coworker.

Attack stages are as follows:

1. A password-protected PDF file is sent alongside an LNK shortcut that imitates a text file containing the PDF's password.

2. When double-clicked, the shortcut file sends an HTTP request to a remote server through Windows utility mshta.exe. This request is intended to download and execute the first-stage payload.
3. The attacker's web server responds with a VBS payload, which will be executed. Additional controls on the server side are present. For example, specialists have observed that the server checks whether the user agent string matches with mshta.
4. The webserver always runs on TCP 8080.
5. The first-stage payload gathers information about the infected system and sends it to the C&C server.
6. The C&C server responds with a second-stage VBS payload, which will be saved in the %TEMP% directory.
7. The malware creates a shortcut file named "xBoxOne.lnk" in the Startup directory as a means of persistence.

APT name	Regions attacked	Operation start
FIN6	USA, Europe	October 2019

October 2019 saw the start of a wave of attacks against financial, construction and trade organizations in the United States and Europe, which lasted for six months. The attacks involved TrickBot, Anchor, and more_eggs. Researchers believe that the developers of TrickBot sold access to compromised networks, where Fin6 later deployed more_eggs.

The attack starts with a phishing email that contains a malicious link to a file hosted on Google Docs named "Annual Bonus Report.doc." Following the link downloads a signed TrickBot loader to the victim machine. When the downloaded file is opened, a message box appears saying that Microsoft Word should be updated to the 2019 version. This window distracts the user from the download and execution of the TrickBot payload, which conducts reconnaissance: steals credentials, browser history, and passwords from KeePass; in addition, legitimate Windows utilities are used to gather information. Collected data is transferred to the C&C server, where the attackers decide whether they are interested in developing the attack further. The threat actors use Meterpreter, Cobalt Strike, and ADfined.exe. Infection with TrickBot is followed by the deployment of the Anchor framework, a new version of Anchor_DNS in particular.

It is believed that Fin6 bought access to targets they were interested in. The access had been obtained using Trickbot, which loaded Anchor. The group then used more_eggs, which had been developed by another hacker, who sold it to a limited number of people on underground forums. The attribution of the detected more_eggs samples to Fin6 is based on similarities in the C&C registration data and the close range of registration dates of the samples in question and a sample the group had used earlier.

Fin6 is a financially motivated hacking group active since 2014. The threat actors' victims are mostly casinos, hotels, retail chains, etc. Information security specialists believe that the hackers are based in Eastern Europe.

APT name	Regions attacked	Operation start

FIN7 (presumably)	-	March 2020

In April 2020, a mailout with the subject “Payment overdue” was discovered. Fin7 is believed to be behind the attack.

The email contained an invoice purporting to be from Myob. The Maob logo and signature in the email could trick the user into opening the malicious document. To view the invoice, the victim is asked to press a button; this opens a webpage from which a .zip archive is downloaded. The archive contains a malicious .vbs loader, which may be Fin7’s new tool, which overlaps with the Griffon malware. The .vbs code contains functions that make it possible to interact with the server through GET/POST requests, receive and execute JS, and collect information about the victim machine and lists of local disks, processes, files, etc. As a result, if the victim is of interest to the threat actors, a GET request to receive JS code will be executed. Several other, similar .vbs files were discovered; the earliest ones are dated March 19, 2020.

Fin7 is a financially motivated Russian-speaking criminal group active since 2015. The threat actors use social engineering techniques and periodically update their attack methods and tools in an effort to bypass detection mechanisms. Most of their attacks target hospitality and restaurant businesses in Europe and the United States.

APT name	Regions attacked	Related notifications	Operation start
more_eggs email campaign	Global	CP-2267	April 2020

On May 4, 2020, Group-IB specialists discovered a mailout containing the more_eggs malware version 6.6b. Either Fin6 or Cobalt may be behind the attack.

The specialists discovered a .zip archive, which was uploaded to VirusTotal in late April 2020. The archive contained an .lnk file, which once launched would download and launch JavaScript. This JS downloaded two files: an empty MS Word document and an executable DLL file classified as TerraLoader.

TerraLoader extracts and launches more_eggs in encrypted (RC4) form; the key depends on the infected system parameters. The more_eggs backdoor supports the following capabilities: downloading and launching executables, executing commands in a command line interpreter, launching/deleting its own copy, and updating.

Financial threats

Malware for Android

Threat name	Detection	Regions attacked	Related notifications
Cerberus v2	April 2020	Global	CP-2244

On April 3, 2020, a user with the nickname ANDROID made a post on XSS.is, an underground forum, about renting out an updated version of the Android banking Trojan Cerberus.

The new application adds to and improves the functionality of the original Cerberus version. Like the original, it is intended for stealing confidential data from Android devices. The updated banking Trojan is distributed via Google Play through light downloader apps, which are not detected by antivirus solutions and are masqueraded as legitimate software.

According to the post, the test version will be available free of charge for those who have already bought the old version of Cerberus. The developer also said that support for the old version would stop on May 1, 2020.

The updated Cerberus can send and intercept SMS messages, show web fakes to the user, record keystrokes (keylogger), launch applications installed on the device, bypass security restrictions and antiviruses, create fake PUSH notifications, and open URLs in the browser.

This malware is an updated version of the Cerberus Android bot created in June 2019.

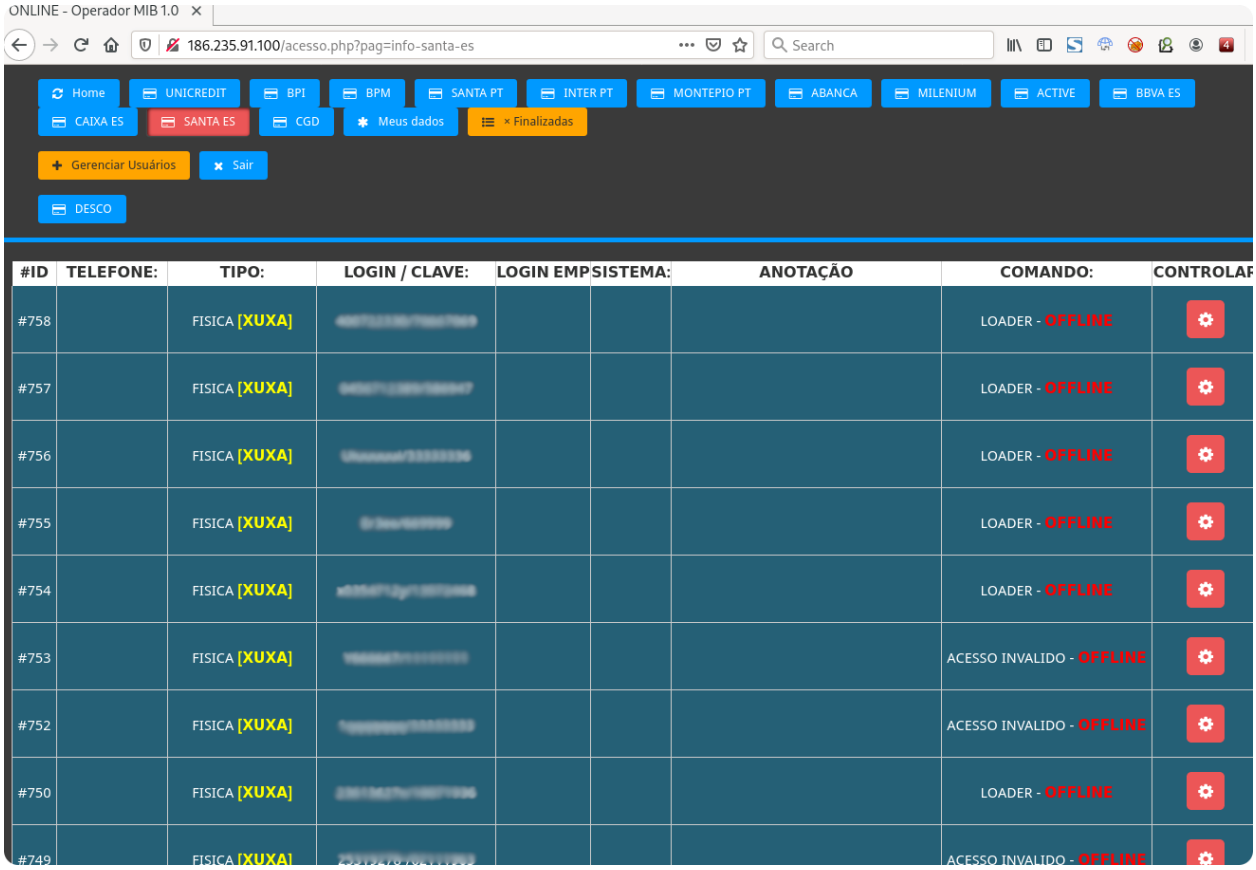
The author later started selling the source code of the malware saying that they would only sell it to one person for $25,000. In late April, the price was lowered to $15,000 and the source code does not seem to have been sold yet.

Threat name	Detection	Regions attacked	Related notification
OperadorMIB	March 2020	Italy, Brazil, Chile, Mexico, Portugal, Spain	CP-2262

In mid-March 2020, cybersecurity researchers published reports on a new Android banking Trojan that targeted Brazil as well as Spanish- and Portuegese-speaking users. Group-IB experts conducted a more detailed analysis of this malware.

It was established that the malware was distributed through phishing.

This is what the admin panel, which is called Operador MIB, looks like:



The malware's functionality includes the demonstration of phishing pages that imitate banks. The analysis of this campaign revealed that in March 2020 the threat actors carried out successful attacks against the customers of the following banks:

Banco del Estado de Chile
Banco Santander Spain
Banco BPI Portugal
Caixa Espania
Millennium BCP
Caixa Geral de Depósitos Portugal
ActivoBank Portugal
Novo Banco Portugal
Bankinter Portugal
Montepio Portugal

In April–May, attacks against Italian banks were detected:
Webank
Unicredit
Ubibanca
Poste
Mps
Intesasanpaolo
Finecobank
Bancobpm

Bper
Bnpparibas
Bnl

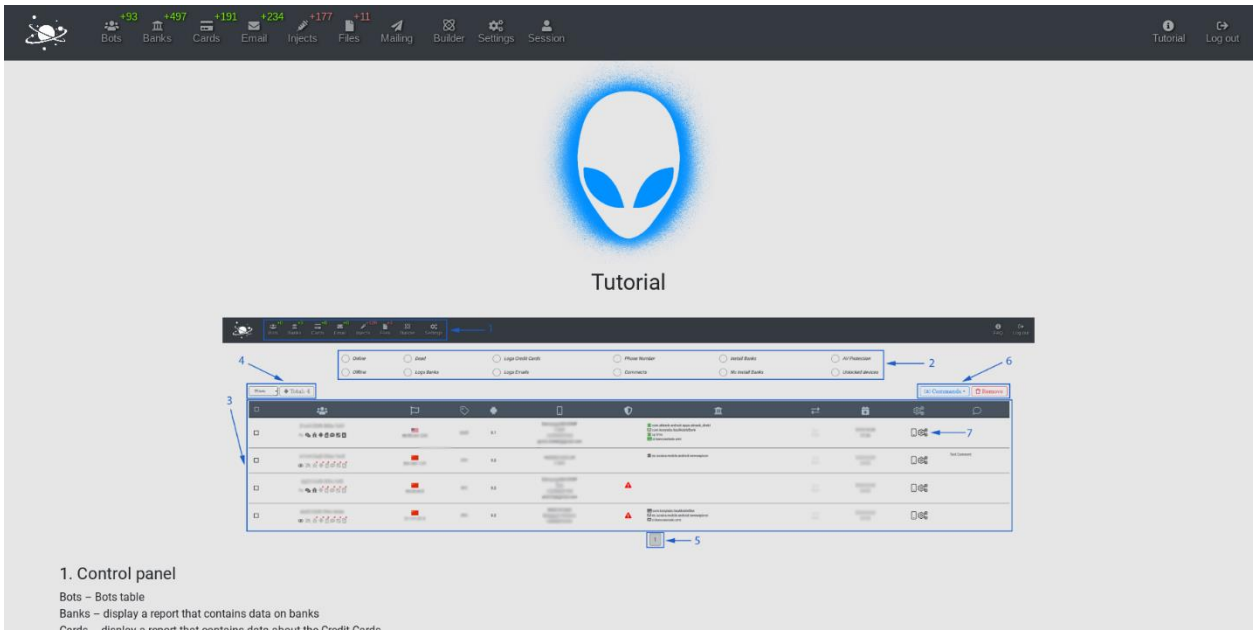
In addition, the analysis of the threat actors' activities revealed the nicknames of the botnet operators; some of the nicknames helped discover their real identity information, which showed that the threat actors were from Brazil.

Threat name	Detection	Regions attacked	Related notifications
Alien Bot	May 2020	Global	CP-2287

Alien Bot is an Android banking Trojan sold at underground foums XSS and Exploit. The developer of the malware is a threat actor with the nickname -ring0-. Alien Bot can be purchased privately through its developer or tech support. At the time of writing this report, there were no pubic messages about the sale of this Trojan.

In May 2020, Group-IB specialists contacted the tech support team and were provided with a detailed description of Alien Bot. The Trojan works on all up-to-date versions of Android (5–10) and can perform the following:

- Stealthily send and intercept SMS messages
- Send USSD requests
- Show push notifications
- Steal email accounts, bank cards, passwords, saved messages, contacts, and a list of installed apps
- Open URLs and download files to the device
- Launch and delete apps
- Log keystrokes (everything except browser)
- Show web fakes (Android injects)
- Intercept and redirect calls (including WhatsApp)
- Intercept Google Authenticator data
- Establish remote access to the device (stealthy installation of Teamviewer)
- Access the file explorer with a possibility to download any file from the device
- Lock the device and turn on silent mode
- Obtain admin rights
- Disable Google Play Protect (the owner has to enter their password)
- Block the possibility of deleting the bot and prevent Accessibility Service from being disabled and Google Play Protect from being enabled



Screenshot: Admin panel home page

Alien Bot support team claims that the program has been developed from scratch. The bot has 177 ready-made Android injects, the rest can be added upon request. The list of injects includes banking apps in the following countries:

- Australia
- United Kingdom
- Germany
- Israel
- India
- Italy
- Canada
- Malaysia
- Netherlands
- Spain
- Peru
- United States
- Thailand
- Turkey
- France
- Czech Republic
- Japan

Threat name	Detection	Regions attacked	Related notifications
Service for creating banking web fakes (InTheBox)	February 2020	Global	CP-2289

On February 17, 2020, a post was published on Exploit.in, an underground forum, about a new service for creating web fakes for Android Trojans Cerberus and Anubis. The poster is known under the nickname InTheBox. At the moment, they offer web fakes with the Android Trojans Cerberus, Anubis, and Alien.

According to the post, the user offered to rent out ready-made web fakes and develop custom ones for apps on GooglePlay. The price of renting a web fake for one month was $10. However, the author also noted that they would start selling them instead of renting out. The price for one web fake was $50; the seller later lowered it to $30.

Below is a list of mobile banking apps, for which Android injects have already been developed:

au.com.nab.mobile
au.com.rams.RAMS
au.com.ubank.internetbanking
ca.bnc.android
ca.motusbank.mapp
ca.pcfinancial.bank
ca.servus.mbanking
ca.tangerine.clients.banking.app
ch.autoscout24.autoscout24
co.zip
com.aadhk.woinvoice
com.abanca.bm.pt
com.aff.otpdirekt
com.akbank.android.apps.akbank_direkt
com.amazon.mShop.android.shopping
com.amazon.sellermobile.android
com.anabatic.canadia
com.bancocajasocial.geolocation
com.bbva.bbvacontigo

com.binance.dev
com.bitfinex.mobileapp
com.cibc.android.mobi
com.coastcapitalsavings.dcu
com.coinbase.android
com.coinbase.android
com.commbank.netbank
com.denizbank.mobildeniz
com.desjardins.mobile
com.exictos.mbanka.bic
com.fibabanka.Fibabanka.mobile
com.fibabanka.mobile
com.fusion.banking
com.fusion.beyondbank
com.garanti.cepsubesi
com.greater.Greater
com.grppl.android.shell.CMBlloydsTSB73
com.grppl.android.shell.halifax
com.grupoavalav1.bancamovil
com.ics.nl.icscards
com.infonow.bofa
com.kasikorn.retail.mbanking.wap
com.krungsri.kma
com.kuveytturk.mobil
com.mycelium.wallet
com.netflix.mediaclient
com.pcfinancial.mobile
com.pttfinans
com.rbc.mobile.android
com.rsi
com.scb.phone
com.scotiabank.banking
com.squareup.cash
com.td
com.tfkb
com.tideplatform.banking
com.tmobtech.halkbank
com.transferwise.android
com.vancity.mobileapp
com.ziraat.ziraatmobil
com.ziraatkatilim.mobilebanking
de.mobile.android.app
de.traktorpool
es.bancosantander.apps
es.lacaixa.mobile.android.newwapicon
eu.atlantico.bancoatlanticoapp

eu.eleader.mobilebanking.invest
eu.eleader.mobilebanking.pekao
finansbank.enpara
hu.bb.mobilapp
hu.cardinal.cib.mobilapp
hu.cardinal.erste.mobilapp
hu.mkb.mobilapp
id.co.bitcoin
il.co.yellow.app
net.bnpparibas.mescomptes
nz.co.bnz.droidbanking
org.banksa.bank
org.bom.bank
pegasus.project.ebh.mobile.android.bundle.mobilebank
piuk.blockchain.android
piuk.blockchain.android
pl.fakturownia
pl.ifirma.ifirmafaktury
pt.bancobpi.mobile.fiabilizacao
pt.novobanco.nbapp
pt.santandertotta.mobileparticulares
sk.raiffeisen.ib.androidwrapper
softax.pekao.powerpay
tr.gov.turkiye.edevlet.kapisi
uk.co.hsbc.hsbcukmobilebanking
uk.co.santander.santanderUK
uk.co.tsb.newmobilebank
wit.android.bcpBankingApp.activoBank
www.ingdirect.nativeframe

Threat name	Detection	Regions attacked	Related notifications
ShadowSinger	February 2020	Malaysia, Vietnam	CP-2288

Group-IB specialists discovered a criminal group called ShadowSinger, which attacked the mobile devices of users in Malaysia and Vietnam.

The threat actors' tactic was to steal banking user accounts through phishing text messages or Android mobile apps disguised as popular applications (e.g. Facebook).

Among the phishing resources were ones disguised as Malaysia National Bank and the Vietnamese Ministry of Public Security.

Threat name	Detection	Regions attacked
Anubis	October 2019	Global

Q2 2020 saw heightened activity of the Android banking Trojan Anubis. It was used in attacks against users in Malaysia, Turkey, Russia, Spain, France, Germany, Italy, Australia, and other countries.

The malware is distributed through Google Play services disguised as legitimate software. It is also spread through phishing pages imitating those of banks.

Anubis's main functionality includes web fakes, USSD requests, interception and sending of SMS messages, and remote access to the target device. Anubis helps obtain full control over the infected device by automatically disabling Google Protect.

Threat name	Detection	Regions attacked
FlexNet	2014	Russia

The Trojan requests device administrative privileges. The request text is masqueraded as a Google Play agreement, which distracts the user and helps access the privileges.

On command from the C&C server, the application can do the following:

- change the C&C server address
- send an SMS message to a specified number
- send bulk SMS messages with a specified text
- forward SMS messages to a remote server
- reply to SMS messages and delete them to conceal the fact from the user
- run USSD requests
- schedule commands: configure a command template for new bots for a particular operator and country

In addition, FlexNet had phishing dialogs added to its functionality. They are disguised as popular applications in order to obtain victims' bank card details. The following fake dialog boxes were detected:
AliExpress
Alpha
Avito
Google Play
MyNewAlpha
telecard
VTB24
Sberbank
Uber

Threats and malware for PC

Threat name	Detection	Regions attacked	Related notifications
JS sniffer mr.SNIFFA	December 2019	Global	CP-2237

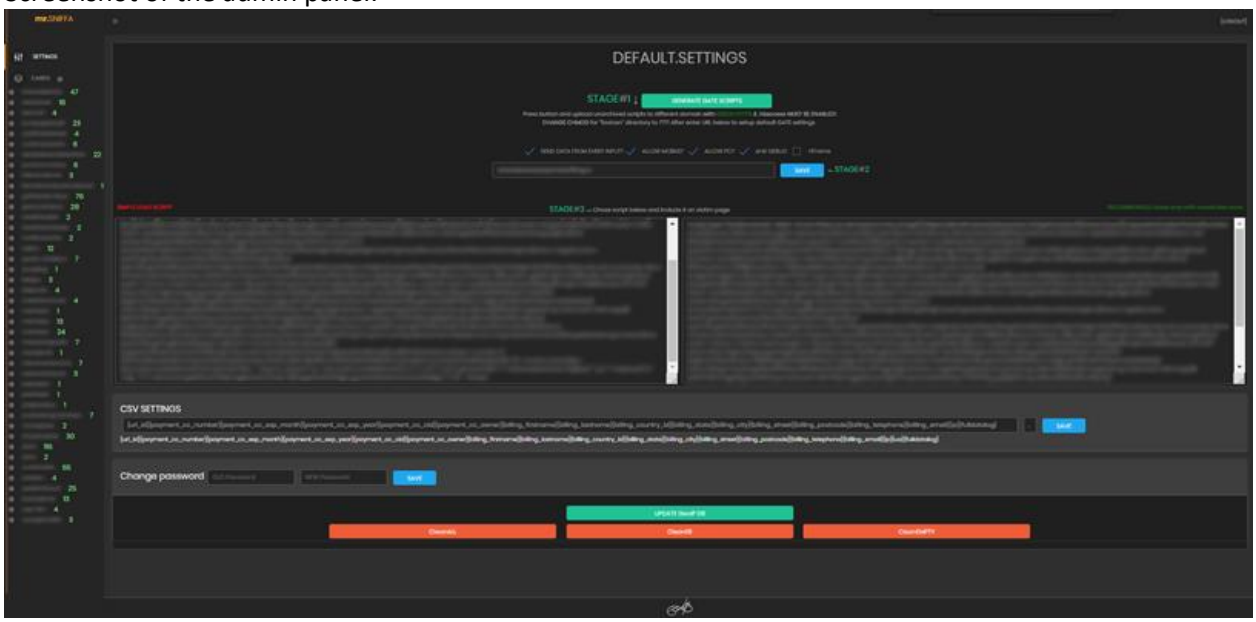
On December 3, 2019, an Exploit.in user with the nickname Billar made a post in which they put up for sale a new bank card sniffer (not fully developed). On March 25, 2020, they started selling the sniffer's release version called mr.SNIFFA.

According to the post, this sniffer is a compilation of various code pieces (from different authors), which the seller put together into one program. The post offers an alpha version, rather than a release version of the sniffer. The seller offered it for $100 to the first users. In March, the threat actor started selling the release verion of their sniffer and also gave it a name, mr.SNIFFA.

The post mentions that its author planned to sell a total of five copies $3,000 each (judging by an analysis of the forum topic when replies to the post were written, we believe that there were two or three buyers. The author also suspended the sale of the updated and improved version of their sniffer until the release date.
Billar mentioned the following special characteristics of their sniffer:

- Data transfer regardless of the browser
- Automatic identification of the country and ZIP code using GeoIP
- Possibility of chaning settings for each website
- Admin panel protected against DDoS attacks, brute force, etc.
- 24/7 support

Screenshot of the admin panel:



Threat name	Detection	Regions attacked	Related notifications
Criminal group Clownz	March 2020	USA	CP-2248

In March 2020, Group-IB specialists started analyzing information related to the criminal group Clownz. It was established that the group had been active since 2014 and had compromised tens of thousands of bank cards. The victims were mostly customers of US banks. At the moment, Group-IB specialists continue to research the group, which is why information about it **is not subject to distribution (TLP:RED)**.

We currently believe that the group may be behind major attacks against the software developer of payment systems 247.ai in 2017 and the hosting service GoDaddy in 2019–2020.

Threat name	Detection	Regions attacked	Related notifications

TinyPosh	April 2020	Russia	CP-2260

In April 2020, an attack against Russian companies involving the TinyPosh Trojan was discovered.

On April 7, 2020, Group-IB specialists detected the upload of malicious LNK files to VirusTotal. It is believed that the attack took place between March 3, 2020 and April 2, 2020. The mailout was carried out under the name of the self-regulatory organization MIR (https://npmir.ru/). The second attack presumably took place on April 24, 2020. The scheme was the same but involved a different decoy document and C&C server. The mailout was carried out under the name of the dentistry Novadent (https://www.novadent.ru/). Once the victim launches the LNK file, they are shown the decoy document while the TinyPosh is being installed on the computer. The backdoor ensures persistence in the system and can download and launch other programs on command from the C&C server.

Threat name	Detection	Regions attacked
PerSwaysion	2019	Global

Group-IB specialists analyzed a series of successful multi-stage phishing attacks against the top managers of more than 150 international organizations from the US, Canada, Germany, the UK, the Netherlands, Hong Kong, Singapore, and other countries. The campaign, which was dubbed PerSwaysion because of its active use of the MS Sway service in one of its stages, has been active since mid-2019.

The cybercriminals primarily attack financial services, law firms, and real estate agencies. The threat actors gain access to the email accounts of high-ranking employees and launch a new round of phishing attacks under their names targeting the victims' business contacts. Group-IB created a website where everyone can check whether their email address has been compromised during the PerSwaysion campaign. Since the threat actors gained access to numerous corporate email accounts and large volumes of business correspondence, this opens up a lot of opportunities for them. The attackers can sell access to accounts to other cybercriminals for financial fraud. Confidential business data extracted from emails can also be sold on underground platforms.

Threat name	Detection	Regions attacked	Related notifications
TA505	2017	Global	CP-2298-1 – CP-2298-4

In June, attacks by the TA505 threat group against companies in Germany and Canada were detected. The attacks involved a tool called Get2, which acted as a loader. SDBot was the payload in some of the attacks. The hackers used their typical tactic: emails with a malicious attachment, usually an HTML document that later loads an Excel file.

Threat name	Detection	Regions attacked
Retefe	2014	Switzerland, Norway

Retefe is a banking Trojan discovered in 2014 and written in JavaScript. It redirects users to fake online banking webpages using a forged certificate and the Tor network and compromises popular web browsers, including Internet Explorer, Mozilla Firefox, and Google Chrome. In 2017, a macOS version known as Dok emerged, which was followed by a version that used the EternalBlue exploit.

In late May, specialists at Sesin reported that this Trojan had been active in Switzerland and Norway. The researchers also noted that the threat actors used Android SMS stealer along with Retefe.

Threat name	Detection	Regions attacked
Trickbot	2016	North America Europe Japan Australia

Trickbot is a banking Trojan that uses techniques similar to those of Dyre. It is distributed through email spam. Lately, however, it has often been distributed using Emotet.

In 2020, Trickbot samples with new features were discovered:

- Bypassing UAC in Windows 10 (it was previously available only for Windows 7) to deliver malware to numerous machines in the network.
- Using Windows 10 ActiveX to execute malicious macros.
- Module for using hacked machines for RDP brute-force attacks.
- In May 2020, Palo Alto Networks discovered that Trickbot's propogation module called nworm had been updated. Infections caused through it leave no artifacts in the victim's domain controller, which disappear after a reboot or shutdown. It is run from RAM. In addition, unlike the previous module (mworm), the new module transfers Trickbot's executable file in encrypted form.

Analysis of detected samples showed that in Q2 2020 Trickbot attacks targeted the following banks (examples):

Royal Bank of Canada
CITIBANK
CAPITAL ONE
Deutsche Bank
Commonwealth Bank
UniCredit bank
Lloyds Bank
ING bank
Raiffeisen Bank
Canadian Imperial Bank of Commerce

Banco Bilbao Vizcaya Argentaria (BBVA)
Rakuten Inc.
Central 1 Credit Union
ABN AMRO Bank
ANZ Bank
NAB (National Australia Bank)
Credit Agricole
Westpac
POSTE ITALIANE S.P.A.
Intesa Sanpaolo
ICCREA
BNL Banca Nazionale del Lavoro
BNP Paribas
Santander
Danske Bank
SpareBank 1
Piraeus Bank

Threat name	Detection	Regions attacked
Gozi (ISFB, Ursnif, Dreambot)	2007	Australia, Italy

In May 2020, Group-IB specialists analyzed a new version of the banking Trojan Gozi/ISFB – Gozi v3. It has the same functionality as that of Gozi 2.X versions. The difference is in the modular architecture. The main features include:

- MITB (Man-In-The-Browser) attacks using web injects
- Theft of user accounts from infected devices
- Execution of CMD commands
- Downoad of files to the infected device and their execution
- Extention of functionality through the download of additional modules from the C&C server
- Video recording

Australian and Italian banks are among the targets.

Australia:
ANZ
Bankwest
Bendigobank
Commonwealth bank
National Australian Bank
Westpac

Italy:

cedacri.it

bnl.it
cdp.it
inbank.it
mps.it
relaxbanking.it
unicredit.it
nexi.it
bancobpm.it
tecmarket.it
bancobpm.it
abi.it
bancaubae.it
bpergroup.net
cariparma.it
bnl.it
intesasanpaolo.com
poste.it

Threat name	Detection	Regions attacked
IcedID (aka Bokbot)	2017	USA, Canada

IcedID was first detected in late 2017. The malware can be used to steal financial information and launch targeted attacks. IcedID is mostly distributed using Emotet but also through phishing emails with a malicious macro that downloads and launches IcedID.

IcedID has a modular architecture and many features of Zeus, including web injects, data theft, and the ability to inject code into other processes. One of the bot's specific characteristics is its ability to deploy a proxy server on an infected machine and redirect all Internet traffic using that server.

In addition to banks, IcedID currently attacks e-commerce businesses. In either case, the criminals' aim is to obtain bank card details: card number, CVV, expiration date, and the region where the victim is located.

In May 2020, Group-IB specialists analyzed a new version of IcedID (21st one), in which configuration files are hidden in PNG images. In an earlier version (e.g. 12), the PNG file only contained the main module.

Another development is the use of the Valak loader to distribute IcedID.

The detected IcedID samples target banks in the US, Canada, and the UK, as well as e-commerce vendors.

Known targets:

Amazon.com
American Express
AT&T
Bank Of America
Capital One
Chase
CIBC
Comercia (comerica.com)
Dell
Discover
Dollar Bank
eBay
Erie Bank
E-Trade
Frost Bank
Halifax UK
Hancock Bank
Huntington Bank

J.P. Morgan
Lloyds Bank
M&T bank
Centennial Bank
PNC
RBC
Charles Schwab
SunTrust Bank
Synovus
T-Mobile
Union Bank (unionbank.com)
USAA
US Bank
Verizon Wireless
Wells Fargo

Threat name	Detection	Regions attacked
RTM	2015	Russia, Belarus, Kazakhstan, Ukraine, Azerbaijan

RTM is written in Delphi and is a modular Trojan. Judging by its functionality, the it targets remote banking services and payment systems. Its latest tracked sample searched for the following remote banking services on infected machines: BSS_PC, Faktura, HandyBank, QiwiCashier, Raiffeisen, RosBank, SberBank_BO, SberBank_Fiz, SberBank_PC, and VTB24.

The RTM group has a main panel and a separate proxy panel showing banks the group targets specifically: all requests are sent to phishing servers where the traffic is proxied.

Since early 2019, mass emails that distribute the RTM Trojan have continued to be actively sent out. We detect such emails almost every day. The recipients are Russian-speaking legal entities.

In late 2019, it was established that RTM was involved in attacks on legal entities in Belarus. The remote banking systems of the following banks were targeted: Belarusbank, BPS-Sberbank, BelVEB, BSB Bank, Belgazprombank, Alfa-Bank, Belinvestbank, Idea Bank, Paritetbank, MTBank, StatusBank, and Belagroprombank.

The malware's main targets are small and medium-sized businesses. However, computers in the infrastructures of large businesses and government agencies are also targeted.

Threat name	Detection	Regions attacked
Danabot	2018	Australia, Europe

The modular banking Trojan Danabot was first detected in the spring of 2018. It uses web injects and intercepts victims' data. It has VNC, Sniffer, Stealer, TOR and RDPWrap modules.

New features were later added to it, namely, several layers of encryption for transferring data to the C&C server and a new loader component with an ability to load plugins along with the main module, which makes it an even greater threat.

In Q2 2020, we detected Danabot that attacked Australia and Germany. In May, numerous emails written in Polish that distributed Danabot and targeted victims in Poland were detected.

Examples of banks attacked:
Australia and New Zealand Banking Group
Westpac
Bank of Melbourne
Bank of South Australia (BankSA)
St.George Bank
Commonwealth Bank of Australia
National Australia Bank

Comdirect
Berliner bank
Norisbank
Targobank
Citibank (PL)
Ideabank (PL)
Bosbank24
Bnpparibas (PL)
Toyotabank (PL)
Plusbank24
Nestbank

Threat name	Detection	Regions attacked
BackSwap	2018	Spain

BackSwap is a banking Trojan, which emerged in 2018.

BackSwap uses a graphical user interface under Microsoft Windows and simulates key presses to avoid detection and bypass browser security. The hackers who developed BackSwap were detected in January 2018, when the group was still distributing its earlier malicious programs, for instance a program for stealing cryptocurrencies that replaced wallet addresses in the clipboard.

Unlike other banking Trojans, BackSwap does not inject malicious code into browser processes since that would be easily detected by antiviruses. Instead, it uses Windows message loop events to know when the victim accesses the online bank and then injects the malicious code into the web page, either via the browser's JavaScript console or directly into the address bar.

We have not seen much activity from this malware since 2018; however, in April we started detecting samples of these Trojan targeting Spanish banks (Caixa, Sabadell).

Threat name	Detection	Regions attacked
Ramnit	2010	Japan, Italy

The banking Trojan Ramnit was first discovered in 2010. In 2015, the Ramnit botnet was taken down by a joint international operation coordinated by Europol. The Trojan's activity, however, did not stop and it continued to be used to compromise bank cards in North America and Europe up until the beginning of 2018. It was followed by a lull, but in Q3 2018 Ramnit resumed its activity. The threat actors focused on attacks against Japan and the United States, occasionally targeting European banks.

In Q2 2020, Ramnit attacks in Japan and Europe were detected.

Threat name	Detection	Regions attacked
Qbot	2009	USA, Netherlands

Qbot (QakBot) emerged in 2009 and has since been regularly improved. Qbot is a modular multithread Trojan that can steal banking data, digital certificates, authentication tokens, and cookies as well as function as a keylogger, backdoor, and SOCKS proxy; it also has antivirus evasion features. Qbot is designed to target businesses and steal money from bank accounts. The Trojan is distributed as a worm by self-replicating through shared drives and removable media.

The configuration file of the latest version of Qbot contains the following targets:

Citizensbank
Capitalone
Firstcitizensonline
Suntrust
Wellsfargo

Frostbank
Scotiabank
Usbank
Bank of America
Abnamro (NL)

Attacks on ATMs and POS terminals

Threat name	Detection	Regions attacked	Related notifications
MagicPos	2020	США	CP-2253

Group-IB specialists analyzed the activity of a criminal group that uses the POS Trojan MagicPos.

They established that the group infected 88 devices and compromised over 67,000 bank cards in the United States.

The specialists detected some of the companies where the infected POS terminals were located:

- Governors State University
- San Francisco International Airport
- ADIRONDACK HOSPITALITY MANAGEMENT LLC
- Arden Realty Inc
- Essex Codey Arena
- Pirates' Cove Children's Theme Park
- Rascal House Pizza Shop - Minnesota
- Rascal House Pizza Shop - Mississippi

MagicPos malware is quite old, it has been known since 2017.

Threat name	Detection	Regions attacked
DispCashBR	December 2019	Brazil

Specialists at Avira discovered a new Trojan for ATMs in Brazil. It is designed for attacks against Wincor and Diebold ATMs. The researchers believe that Portuguese-speaking threat actors are behind these attacks, since the code contains comments in Portuguese.

It was established that the Trojan had been written in C and compiled using a MinGW GCC compiler.

The code contains interesting strings that indicate that the program looks for the code of the currency inserted into the ATM and specifies the following ones:

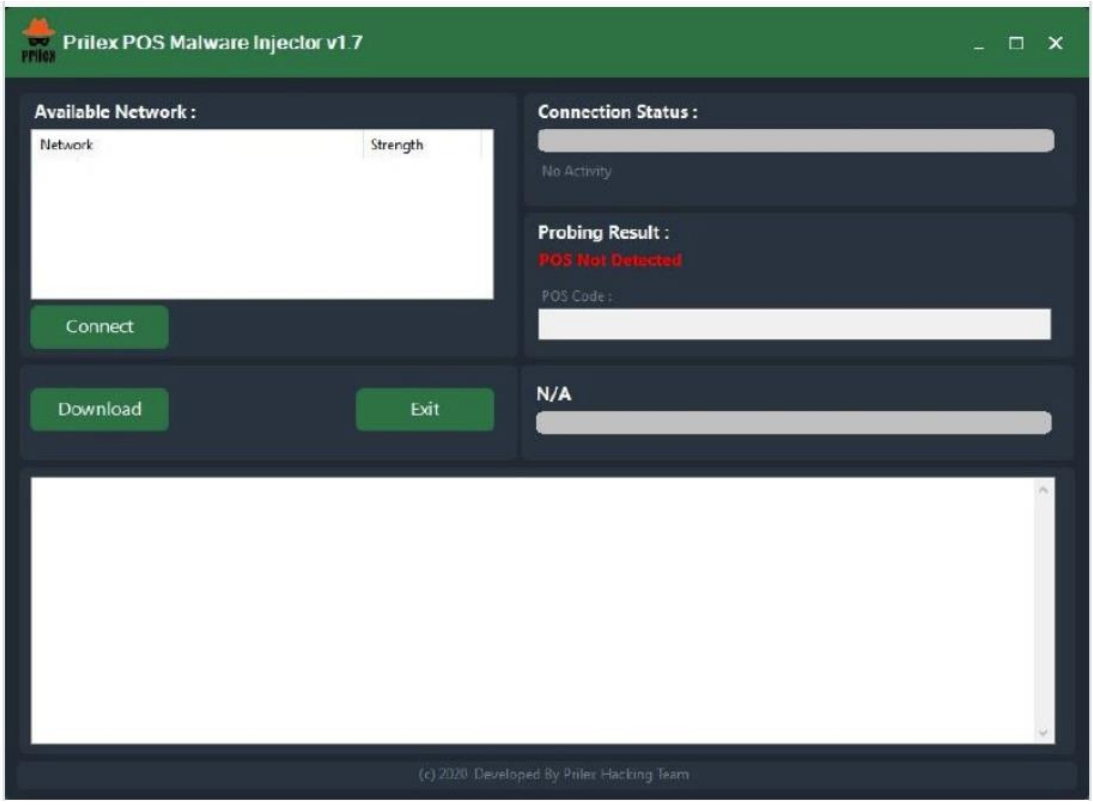
- BRL — Brazilian real
- USD — United States dollar
- ARG — the malware authors may have meant ARS (Argentine peso)
- EUA — Euro (EUR)
- AFA — Afghan afghani (AFN)

- MEX — the malware authors may have meant MXN (Mexican peso)

The Trojan's operation results in the ATM dispensing cash.

Threat name	Detection	Regions attacked
Prilex POS	2018	Global

June 2020 saw the discovery of a shop that sells Prilex POS, which is a malicious program designed to attack wireless POS terminals. The program was first detected in 2018. Its price is $3,500.



The post says that the malware scans networks for vulnerabilities and can directly connect to a POS terminal and then send data (T1, T2, PIN, and EMV) to the threat actor.

Ransomware

Threat name	Detection	Regions attacked	Related notifications
Maze	April 2020	France, Costa Ria, USA, Singapore, Puerto Rico	CP-2255

In April 2020, the threat group Maze published compromised information of the companies Bouygues Construction (France) and Banco BCR (Costa Rica) on their news websties (newsmaze[.]top). Both companies had been attacked earlier: in January 2020 and August 2019 respectively. The publication of the data means that the victim companies did not pay a ransom to the threat actors.

Maze Team official press release. April 30, 2020

Banco BCR

In August 2019 one of the major backs in Costa Rico **Banco BCR** was attacked by Maze Team. At that time we have deveped new hacking tools and methods and examine the security systems. According to Financial Institutions Protocol this bank had to notify other institutions about the security breach case. But nothing was made. Servers and workstations were not blocked. Private data was not secured. Anyway the Bank decided to conceal information about the breach. Though the security personel were able to analyze the attack logs and to see that the attackers have accessed the payment processing system. We have stopped the attack as the possible damage was too high.

In February 2020 we have made a routine check of previously accessed systems. And we found the that nothing was made. In the security perimeter was a hole as large as the Channel tunnel. We decided not to block the work of the bank. It was at least incorrect during the world pandemic. But we have taken the private date for at least a few years including transaction info and history and and credit cards. It means we have got over **11 milion credit card** credentials. Over 4 millions of those credit cards are unique. 140 000 belongs to US citizens.

That info can be easily sold on Dark Market and earn a few million dollars. But the Maze Team is not selling the private info of dark market or steal money from users. We are trying to alert people and financial institutions about the poor security. We are trying to focus on security breach that inpacts not only Banco BCR but also other financial institutions whose credit cards were processed by Banco BCR.

Banco BCR doesn't care about the security of other people's funds. All they are interested in getting more money from the clients. They behave like loan sharks trying to give the most expensive credit and foreclosed your property.

We are informing the Banco BCR, media sources and regulators about that case. We will also publish all the info at our news website if we didn't receive any feedback. It mean that all 11 millions credit card numbers and other credentials will be published. And we'll watch fpr the consequences.

458946464027XXXX=2403201252788951	415276099958XXXX|2035|01|139|
516327961952XXXX=22032011800690400000	415276082630XXXX|2023|10|829|
557435102518XXXX=21112210000003619900	461164009352XXXX|2021|08|952|
551898001549XXXX=20062015280000000000	461164002960XXXX|2022|04|096|
5261040009958XXXX=20032011702257600000	461164003401XXXX|2022|04|971|
414282060033XXXX=24122011868397500000	472057001581XXXX|2022|03|075|

April saw another incident believed to be related to Maze. The US multinational corporation Cognizant, which offers IT services, announced on April 18 that it had been attacked. The indicators related to the

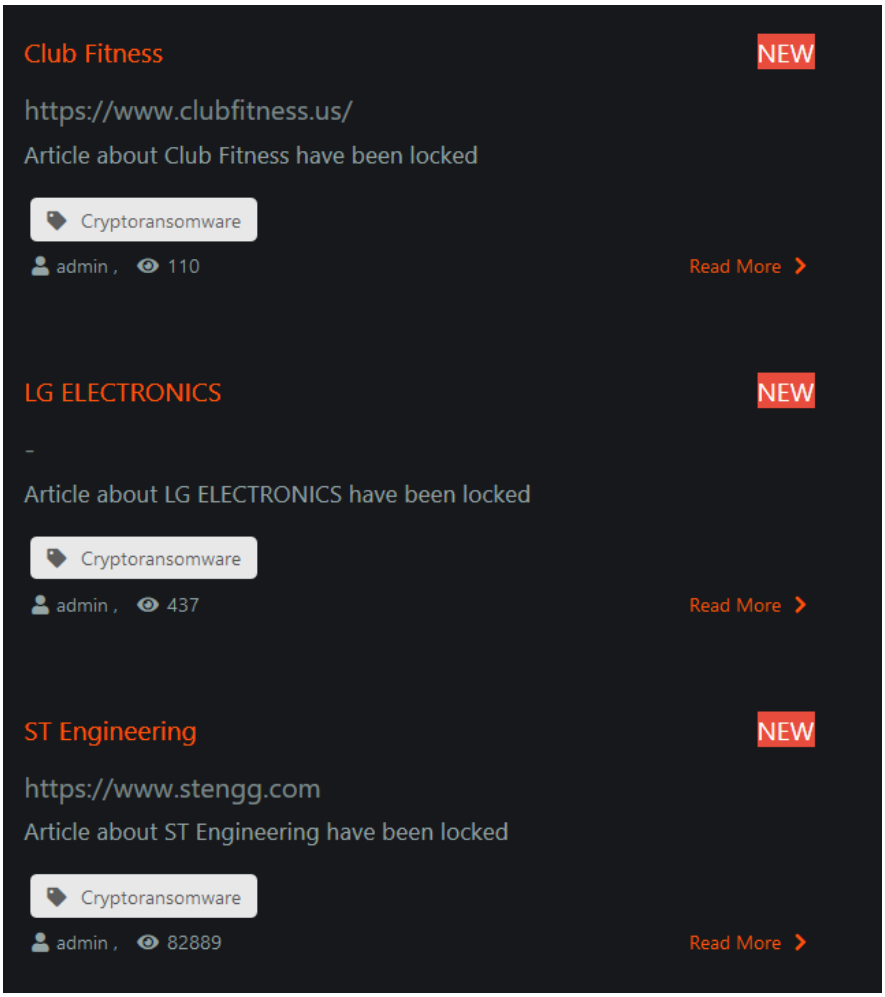
incident, which Cognizant provided their partner companies with, signify that the attack was carried out by Maze.

However, Maze did not claim responsibility for the Cognizant hack. The threat actors are most likely not prepared to discuss this incident in order not to complicate matters while the ransom is negotiated (there have been such precedents). As at mid-May, the Maze website did not have Cognizant's compromised information published.

In their analysis of Maze's activities, Group-IB specialists made an assumption that the attackers may have cooperated with the underground service SHERIFF, which compromises companies' IT infrastructures.

In June, the threat actors published data on the following companies: ST Engineering (Singapore), MaxLinear Inc (USA), Conduent Inc (USA), M.J. BRUNNER Inc (USA), Columbus Metro Federal Credit Union (USA), WorldNet Telecommunications (Puerto Rico), Xerox Corporation (USA), LG ELECTRONICS, and Club Fitness (USA).

Regarding the last companies in the list above, the threat group only publishes screenshots and does not share full archives: they will most likely be published later.



Threat name	Detection	Regions attacked

Attack against Diebold Nixdorf involving ProLock	May 2020	USA

The ProLock ransomware emerged in March 2020 as the successor to PwndLocker, which started operating in late 2019. ProLock attacks primarily target financial, medical and government organizations as well as the retail segment.

On May 11, the ATM manufacturer Diebold Nixdorf confirmed that it had fallen victim to a ProLock attack. The company said that the incident had almost no effect on its operation, i.e. it did not affect ATMs nor customer networks; rather, it only caused a small failure of a limited number of IT systems in the corporate network of the manufacturer itself. Diebold Nixdorf said the company did not intend to pay the threat actors a ransom.

Group-IB specialists have established that the operators of ProLock use two main vectors of initial compromise: the QakBot (Qbot) Trojan and unprotected Remote Desktop Protocol (RDP) servers with weak passwords.

Compromise through an externally accessible RDP server is extremely popular among ransomware operators. Threat actors usually buy access to a compromised server from a third party, but can gain it independently too. A more interesting initial compromise vector is QakBot. This Trojan used to be associated with a different ransomware family, MegaCortex, but is now used by ProLock operators.

QakBot is usually distributed through phishing campaigns. A phishing email can contain an attached Microsoft Office document or a link to such a file stored in the cloud, e.g. Microsoft OneDrive.

There have also been cases when QakBot was downloaded by another Trojan, Emotet, which is notorious for being used in campaigns that distributed Ryuk ransomware.

The threat actors ensure persistence in the system, bypass security, obtain credentials, conduct network reconnaissance, move laterally, collect and exfiltrate data, and — obviously — lanch the ransomware in the network of a company they attacked. ProLock adds the extension .proLock, .pr0Lock, or .proL0ck to each encrypted file and puts the file “[HOW TO RECOVER FILES].TXT” in each folder. This file contains information about how to decrypt files, including a link to the website where the victim should enter a unique ID and receive payment information.

Threat name	**Detection**	**Regions attacked**
REvil (Sodinokibi)	2019	USA

In May, the REvil (Sodinokibi) group attacked a US law firm called Grubman Shire Meiselas & Sacks. On their blog (dnpscnbaix6nkwvystl3yxglz7nteicqrou3t75tpcc5532cztc46qyd[.]onion), the threat actors posted screenshots and parts of documents showing that they had gained access to the company’s folders and files.

Happy Blog

Blog search | Search

GRUBMAN SHIRE MEISELAS & SACKS

GRUBMAN SHIRE MEISELAS & SACKS
Entertainment and Media Lawyers

It seems that GRUBMANS doesn't care about their clients or it was a mistake to hire a recovery company to help in the negotiations. As we promised, we public the first part of the data because the time is up.

http://gsmlaw.com

Clients:
Madonna
Facebook
Elton John
Barbra Streisand
Lady Gaga
and others...

Contracts, telephones, email, personal correspondence, NDAs and more... (756Gb)

Download 1(2,4Gb, Lady Gaga)**link updated.** The sponsor of this information is the company Coveware and their greed
Download 2(100Gb) - will be soon
Download 3(100Gb) - will be soon
Download 4(100Gb) - will be soon
Download 5(100Gb) - will be soon
Download 6(100Gb) - will be soon
Download 7(100Gb) - will be soon
Download 8(100Gb) - will be soon
Download 9(55Gb) - will be soon

ABG-SI	Adam Rosen Files	Bette Midler	Bruce Springsteen
Cam New	DiGa Fully executed agreements	Ella Mai	executed agreements
Facebook	Film&TV Executed Agmts	Gagosian - Jagger Project	Groot
GYK	HotDocs	Idina Menzel	Jessica Simpson
JMB	Kalamoutsos	Kathy Savitt	KMeiselas
Lady Gaga	Last Week Tonight	LN	Madison Beer
Madonna	MARIAH CAREY	Mary J. Blige	Matoma
My eBooks	NEG Operations (CORE)	Nicki Minaj	OutKast & Andre 3000
PDH Stripe Invest	Priyanka Chopra	Project Herb	Project Ocean VDR
PROSKAUER LITIGATION	RRHOF	Run DMC	SEP
Shared Artists KM	Starshell	STRENT Agreements	SWG
U2 Producer Booklet Volume 3	U2 Publishing Agreements Vol 2	U2 Record Agreement	UNSCRIPTED REALITY TV DOCUME...
Worldwide Pants Incorporated			

aavila	acaban	ADeRosa	administrator
AGhotikar	AGoldstone	AGrubman	AIndursky
ajames	ajgrubman	AKaplun	amatza
aowens	arobbins	aromanello	arosen
ARusso	ascimeca	AVaughn	Backup_Exac
bdonahoo	bfurtado	bjustie	bmaggi

The attackers claimed that the total amount of stolen information was 756 GB, including contracts, phone numbers, email addresses, personal correspondence, non-disclosure agreements and a lot of other information related to the company's customers.

In June, the threat actors started an auction for the data of the company Intercard Inc., a US bank card service provider. According to the threat actors, the body of data includes documents from the company's various departments, information about its customers, and various versions of firmware for POS terminals.

Threat name	Detection	Regions attacked
Snake (Ekans)	June 2020	Japan, Europe

On June 8, 2020, the company Honda announced that its computer networks in Europe and Japan had suffered a cyberattack. The incident affected some of the company's operations, including manufacturing systems outside Japan.

Cybersecurity researchers established that this attack may have involved Snake (Ekans) ransomware, since related files were uploaded to VirusTotal.

Snake operators have so far regused to comment on the situation neither confirming nor refuting their involvement in the incident. They may be negotiating with the attacked company on a ransom.

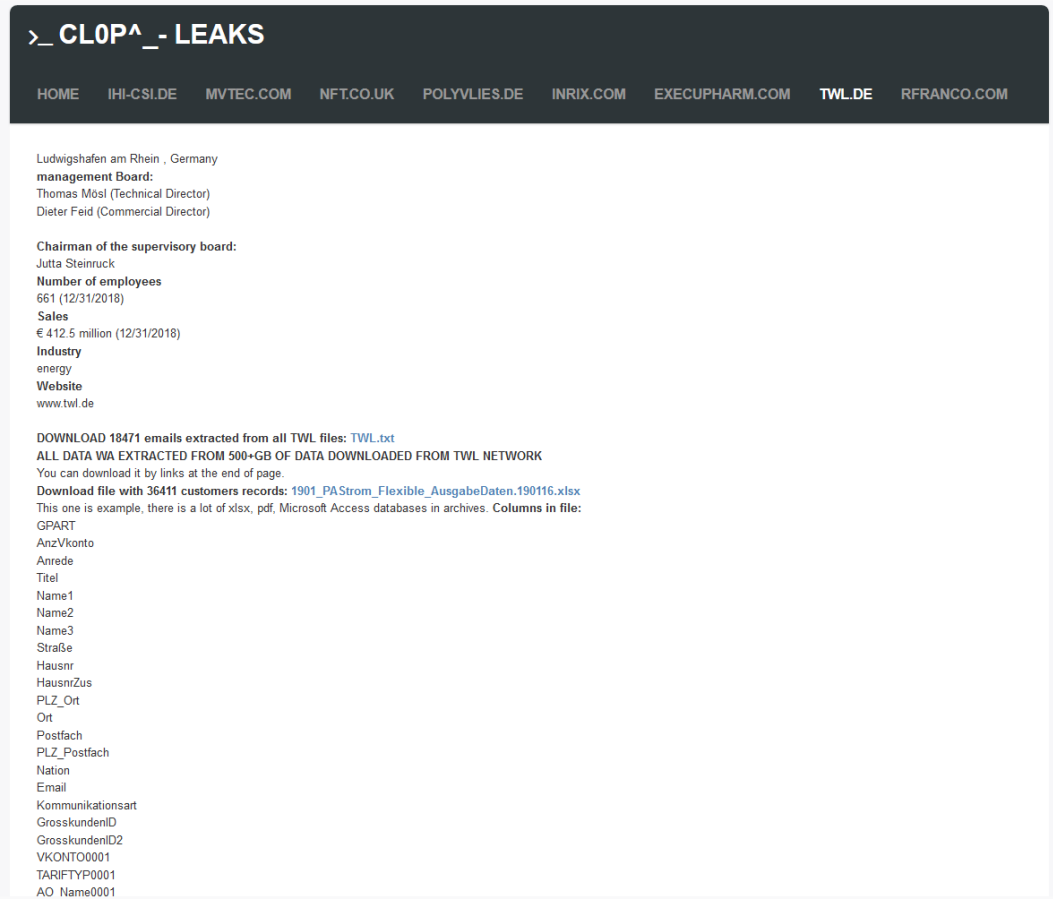
Snake also attacked the energy company Enel, namely its subsidiary Edesur S.A., which is based in Argentine.

Snake ransomware was discovered in December 2019.

Threat name	Detection	Regions attacked
Attack against Technische Werke Ludwigshafen (TWL) involving Clop Ransomware	May 2020	Germany

On May 5, the power supplier Technische Werke Ludwigshafen (TWL) reported a cyberattack; no details were provided.

On May 11, a resource belonging to the operators of the Clop ransomware published 30,000 records about TWL customers, which suggests that the Clop ransomware was behind the attack and that the victim company did not pay a ransom, which resulted in the compromised data being published. The data contained customer names, email addresses, tariffs, and account numbers.


>_ CL0P^_- LEAKS

HOME IHI-CSI.DE MVTEC.COM NFT.CO.UK POLYVLIES.DE INRIX.COM EXECUPHARM.COM TWL.DE RFRANCO.COM

Ludwigshafen am Rhein , Germany
management Board:
Thomas Mösl (Technical Director)
Dieter Feid (Commercial Director)

Chairman of the supervisory board:
Jutta Steinruck
Number of employees
661 (12/31/2018)
Sales
€ 412.5 million (12/31/2018)
Industry
energy
Website
www.twl.de

DOWNLOAD 18471 emails extracted from all TWL files: TWL.txt
ALL DATA WA EXTRACTED FROM 500+GB OF DATA DOWNLOADED FROM TWL NETWORK
You can download it by links at the end of page.
Download file with 36411 customers records: 1901_PAStrom_Flexible_AusgabeDaten.190116.xlsx
This one is example, there is a lot of xlsx, pdf, Microsoft Access databases in archives. **Columns in file:**
GPART
AnzVkonto
Anrede
Titel
Name1
Name2
Name3
Straße
Hausnr
HausnrZus
PLZ_Ort
Ort
Postfach
PLZ_Postfach
Nation
Email
Kommunikationsart
GrosskundenID
GrosskundenID2
VKONTO0001
TARIFTYP0001
AO_Name0001

Threat name	Detection	Regions attacked
Nefilim	March 2020	Global

The threat group Nefilim published information about the companies W&T Offshore (USA), MAS Holding (Sri Lanka), Arteris SA (France), Cosan (Brazil), Aliansce Sonae (Brazil), Toll Group (Australia), Aban Offshore (India), and Fisher & Paykel (New Zealand). The group is highly active at the moment and its geographical scope covers various countries. Nefilim is a modified version of Nemty ransomware.

RECENT POSTS

MAS Holdings. Part 4-5. June 13, 2020

Fisher & Paykel. Part 1. June 10, 2020

Aban Offshore. Part 8. June 7, 2020

Toll Group. Part 2. Second part of the leak includes documents on Samsung. June 5, 2020

W&T Offshore. Part 3. June 2, 2020

Arteris SA. Part 3. May 31, 2020

Stadler Rail. Part 1. May 29, 2020

Cosan. Part 5. May 26, 2020

Aban Offshore. Part 7. May 22, 2020

Toll Group. Part 1. May 20, 2020

Threat name	Detection	Regions attacked
DoppelPaymer	June 2019	Global

The threat group that uses the DoppelPaymer ransomware was also highly active and published data on 24 companies on their blog:

Commercial Development Company, Inc.
Van Boxtel RV
Go West Tours
LIWA NATIONAL ENGINEERING
AFPA
Container Marketing, Inc

Boom Construction Company
Banka Ekonomike
City of Torrance, CA
D'Asign Source
Chris-Marine
Kent County Trading Ltd
ICM - International Commerce & Marketing Corp
Phipps Dickson Integria (PDI) Inc
Roger Martin
Clopay Ames True Temper Holding Corp.
Wolverine Freight System / Ontario Limited
Siegel Egg Co, Inc.
Digital Management, LLC
LOGÉAL IMMOBILIÈRE
Charleville Mézière
Callaway Architecture, LLC
USDAFMMA
Goodwill Industries of Kanawha Valley, Inc.

Exploits

Threat name	Detection	Regions attacked	Related notifications
Sale of a 0-day exploit for Internet Explorer	April 2020	Global	CP-2263

Group-IB specialists discovered a post that advertised the sale of a new 0-day exploit for Internet Explorer for Windows 8-10. The exploit targets two vulnerabilities Remote Code Execution and Sandbox Escape. According to the seller, Microsoft has not yet released recommendations on these vulnerabilities.

The post says that the seller offers an RCE exploit together with Sandbox Escape for Windows 8-10. For the exploit to run, the user needs to open an HTML page. The exploit does not require any interaction with the page.

The seller of the exploit mentioned the following features:

- The payload has to be in DLL format and will be loaded in rundll32
- Rundll32 is launched with current user rights and medium integrity level
- Internet Explorer does not crash
- The exploit can be executed again; execution of multiple payloads is also possible
- Works in the iframe style=display.none element
- Exploit execution time includes the payload downloading time plus two seconds

Price of the exploit is 6 BTC.

There have been no updates in the forum topic after that.

Threat name	Detection	Regions attacked	Related notifications
Exploit kit for Microsoft Excel (Solmyr)	February 2020	Global	CP-2299

On February 11, 2020, a user with the nickname Solmyr created a post on Exploit.in, an underground forum, about renting out an exploit kit for Microsoft Excel.

According to the post, the exploit kit is made up of two exploits: Silent and Macro combined in one file. The author says that Silent targets the 1-day vulnerability CVE-2017-11882 and affects almost all versions of Microsoft Office, while the Macro exploit affects all versions.

CVE-2017-11882 is a remote code execution (RCE) vulnerability, which occurs in Microsoft Office when the software fails to properly handle objects in memory. Exploitation of the vulnerability requires that the user open a specially crafted file with an affected version of Microsoft Office. In an email attack scenario, an attacker could exploit the vulnerability by sending the specially crafted file to the user and convincing the user to open the file. An attacker who successfully exploited the vulnerability could run arbitrary code in the context of the current user.

On November 29, 2017, Microsoft released security updates for its products that patched this vulnerability.

In the post, the seller says that the license for using this exploit kit is valid for one month and costs $1,250. Solmyr highlighted that they release updates for their product regularly on Wednesdays and Sundays.

State-sponsored APTs

APT name	Regions attacked	Operation start
Lazarus	Global, South Korea, France	April 2020

In the morning of April 1, 2020, malicious emails purporting to be from the Incheon Communicable Diseases Center Support Group were detected.

The emails were distributed with the title "Response to Coronavirus in Incheon Metropolitan City" with the origin "[Emergency Inquiry]" and the sender email address was icdc@icdc.incheon.kr.

In the emails, the attackers say that a COVID-19 virus outbreak has occurred among certain participants and that the email recipients have also been reported to attend the same meeting. In addition, they are instructed to fill out and submit a specific time zone line as an attached form file and induce the execution of the attached file.

When the user executes the attached HWP document, a Korean document titled "Emergency Search" is executed, and at the same time, malicious code disguised as a Chrome update module through a C&C server (teslacontrols.ir) exploiting the vulnerability secretly continues to function.

The malicious code executed on the user's computer collects information about files and folders and can secretelly install additional malicious files through additional download commands.

On April 21, 2020, Group-IB specialists discovered links to phishing documents that distribute Lazarus's (CuriousLoader) and download Manuscrypt to targeted systems.

The links download the following MS Word documents:

- MzBfMjA1Njc0ODhf
- MzBfMjA1Njc0ODdf

The document MzBfMjA1Njc0ODhf contains a remote DOTM template, which presumably executes a malicious macro.

The document MzBfMjA1Njc0ODdf contains a malicious macro, which is executed when the document is opened, and also two executables within. The executables are Base64-encoded and stored in VBA form. Only one of them is executed, depending on the system bitness (x32/x64).

The executable is extracted to the directory %USERPROFILE%\AppData\Local\Microsoft\OneNote\ with the name "onenote.db," which is a loader that can be classified as Lazarus.CursiousLoader.

Once the file has been extracted to disk, the macro calls the function LoadLibraryA from kernel32.dll and loads the executable as a library (DLL) in its own process (WINWORD.EXE), it then calls the function CoContentInfo from the loaded library (onenote.db).

This function adds itself to Startup by creating an LNK file in %APPDATA%\Microsoft\Windows\Start Menu\Programs\Startup\onenote.lnk. It also launches another copy of itself through rundll32 calling the exportable function CMS_ContentInfo. This function starts the full operation of the loader.

aes_key (S-6-38-4412-76700627-315277-3247) is passed to the CMS_ContentInfo function as an argument to decrypt internal configuration.

CMS_ContentInfo checks if all command line arguments are present and valid, calculates the MD5 hash of aes_key, and decrypts the configuration, which is contained in the executable file. AES-128 in CBC mode with IV (Initial Vector) = 0x00000000 is used as an encryption algorithm.

The configuration contains a C&C server that the loader communicates with to receive the payload: https://www.elite4print.com/admin/order/batchPdfs.asp. In response, the server sends the payload, Lazarus.Manuscrypt.

Not everyone can receive the payload: the server has a whitelist and blacklist of IP addresses. If an IP address is in the whitelist, it will receive the Lazarus.Manuscrypt payload, taking into account the bitness of the infected system.

Both lists are continuously updated and expanded. The blacklist contains the IP addresses of researchers that analyze this attack and try to obtain the payload from the C&C server.

Later, on April 24, 2020, Group-IB specialists discovered a Word document called "Boeing_PMS.docx," which was uploaded from France and contained a malicious remote DOTM template.

The DOTM template contains the same macro as the one in the document MzBfMjA1Njc0ODdf. It contains similar payload, which can be classified as Lazarus.CuriousLoader, with the same C&C server (elite4print.com), but a different unpacking path (%USERPROFILE%\AppData\Local\Microsoft\Notice) with the file name "wsuser.db." The function that creates an LNK file in the Startup folder contains the path %APPDATA%\Microsoft\Windows\Start Menu\Programs\Startup\preview.lnk.

The attack targeted the arms and heavy industries.

On April 27, 2020, another email campaign by Lazarus was discovered. The hackers disguised themselves using a document with a description of a vacancy at KHNP (Korea Hydro & Nuclear Power Co., Ltd.).

Korea Hydro & Nuclear Power is a subsidiary of Korea Electric Power Corporation. It operates large nuclear and hydroelectric plants in South Korea, which are responsible for about 30% of the country's electric power supply.

Lazarus (also known as Dark Seoul Gang, HIDDEN COBRA, and Guardians of Peace) is a cybercriminal group active since 2007. Specialists have established that the group's members are from North Korea.

APT name	Regions attacked	Operation start
Kimsuky	South Korea	2019

In April 2020, Kimsuky continued its malicious mailouts. The malicious files used in this attack are disguised as "21대 국회의원 선거 관련.docx" [21th National Assembly.docx] and "외교문서 관련(이재춘국장).docx" [Diplomacy-related documents] (Director Jae-chun Lee).docx].

The names of the two malicious Word files found this time are different, but the operation method is the same.

First, when the malicious DOCX document is executed, the internal command **settings.xml.rels** is used, which attempts to communicate with a specific C&C server to execute the malicious macro function.

The author of the DOCX document is registered with the name "seong jin lee" and the last modifier is "Robot Karll."

The victim is shown a phrase to induce a click on the Enable Content button. If communication with the C&C server fails, however, the [Enable Content] button does not appear.

When the malicious macro runs, it creates an additional command with the file name ".NETFramework4.xml."

And, like the Windows operating system activation key management service (Key Management Service), it is registered in the task scheduler with the name KMSAuto and is set to run automatically.

It attempts to communicate with the C&C server and depending on the additional command from the attacker, various information leaks may occur.

In addition, in May 2020, Kimsuky used fake ESET security software update program. Its launch if followed by a window saying that ESET software has been successfully updated.

The virus will first create the mutex GoogleUpdate_01 to prevent multiple runs. To avoid killing the virus, all functions, files, file paths and registry names used are encrypted.

The specialists noticed that the requested data was tagged as tiger, etc. The program recognizes these signs and then performs different actions. If it is tiger, the cmd instruction will be executed through the WinExec function. The experts discovered that these instructions were designed for collecting information such as device systems, files, and drives.

The malware then writes this information to the “tmp.log” file in a temporary directory and sends it back to the server.

The data instructions returned by the C&C server are all given animal names and the sample also parses this. In addition to the tiger logo, there are lion, wolf, monkey, fox and cat logos, and the processing method corresponding to each logo is different. For example, the monkey logo will execute the downloaded file by creating a process.

If it is related to the fox logo and cat logo, in addition to the executable file, it will also work with registry information.

In May–June 2020, Kimsuky continued their malicious mailouts as part of Operation Smoke Screen. In their attack, the threat actors used various file formats such as .doc, .hwp, and .exe.

The malicious DOC document shows the contents of PROTECTED DOCUMENT upon its first execution, and deceives the user as if the body is not displayed due to the security function of the document. The document prompts the user to click on the [Enable Content] button to run the malicious macro code.

If the user ignores the security warning and clicks on the [Enable Content] button, the malicious code is executed and shows normal text content, misleading the victim into thinking that it is a normal document.

The author of the document contains the name Robot Karll, which has been seen in a number of Kimsuky attacks.

When the data declared as a HEX string is converted to ASCII code, a trigger that repeats indefinitely every 3 minutes with the name OneDrive is registered in the task scheduler to communicate with a specific C&C server.

On June 2, 2020, security specialists discovered a malicious file in .hwp format. The document was produced on May 4 and named “드론(무인항공기) 현황 및 개선방안.hwp” [Drone (unmanned aerial vehicle) status and improvement plan.hwp].

The hwp document contains Post Script code and calls the encoded shell code. The shellcode included in the Post Script creates a task scheduler to attempt to communicate with a C&C server through the decoding routine. As with the .doc file, this time the covertly registered task scheduler name is OneDrive.

Malicious files created in April were disguised as AES256 decryption programs.

The file name is “AES256 Decryptor.exe,” and the icon resource is produced in Korean.

The malicious files have a function of decrypting encrypted files and perform malicious functions together. When executed, they show the actual decryption function screen and wait for the file to be decrypted.

The attacker sends the encrypted file "CIA Final Answer-Attachment.docx.enc" to the target of the attack to induce the user to decrypt the file. In fact, when decoding is in progress, some headers are damaged, but when a recovery attempt is made, the actual document appears.

However, if you look at the properties of this document file, you will find the same Robot Karll account as in the .doc document. So you can see that the doc, hwp, and exe attacks are all linked with the same attribute.

Kimsuky attacks South Korean defense companies, foreign and security sectors, and key personnel in North Korean organizations.

Kimsuky (also known as Velvet Chollima and Black Banshee) is a hacker group believed to be based in North Korea. The group has been actively attacking entities in the South Korean territory since 2010, but has lately been expanding the geography of their attacks.

APT name	Regions attacked	Operation start
APT41	North America, South America, Taiwan	January 2020

A global attack campaign by the espionage group known as APT41 was discovered in March. This attack campaign was thought to have operated between January 20 and March 11, specifically targeting Citrix, Cisco, and Zoho network appliances via the exploitation of recently disclosed vulnerabilities. Multiple victims were identified in industries such as healthcare, higher education, manufacturing, government and technology services in multiple regions around the world, such as North America, South America, and Europe.

The payload was made up of executable files compiled to run on FreeBSD and was named Speculoos. Speculoos was delivered by exploiting CVE-2019-19781, a vulnerability affecting Citrix Application Delivery Controller, Citrix Gateway, and Citrix SD-WAN WANOP appliances that allowed an adversary to remotely execute arbitrary commands. This vulnerability was first disclosed on December 17, 2019 via security bulletin CTX267679, which contained several mitigation recommendations. By January 24, 2020, permanent patches for the affected appliances were issued.

After successful launch, the payload connected to the C&C server and completed the TLS handshake. In this moment, the program fingerprinted the victim system and sent the data back to the C&C server. Once it received a response, Speculoos entered a loop to receive commands, such as instructions on creating a remote shell, kill the process and/or remove the file, and other functions.

APT41 also exploited the CVE-2020-10189 vulnerability in Zoho ManageEngine, which allows for remote code execution without authorization with super user or SYSTEM rights. The next day after CVE-2020-10189 was fixed, the threat actors attacked over a dozen systems and compromised at least five of them. They then deployed a trial version of the Cobalt Strike BEACON loader and employed another backdoor for downloading VMProtected Meterpreter.

APT41 (also known as BARIUM, Winnti, LEAD, Axiom, Group 72, and Double Dragon) is a Chinese state-sponsored threat group active since 2012. The group's espionage campaigns have targeted healthcare, telecommunications and high-tech sectors and have historically involved intellectual property theft. APT41's attacks have targeted the gaming industry, including the manipulation of virtual currencies and attempted deployment of ransomware.

APT name	Regions attacked	Operation start

TwoSail Junk	Hong Kong	January 2020

Earlier this year, security experts discovered a large-scale watering hole attack targeting Hong Kong residents, in which multifunctional iOS malware called LightSpy was installed on the victims' smartphones.

LightSpy infected smartphones when the victims visited webpages disguised as local news resources. Links to these websites were spread through posts on forums popular in Hong Kong.

Visiting these resources downloaded a number of exploits to the visitors' smartphones, which resulted in the installation of LightSpy. Researchers say that LightSpy is a modular backdoor that allows the threat actor to execute various commands on the infected device. For example, it can determine the smartphone's location, obtain contacts and phone call history, see what Wi-Fi networks the victim connected to, scan the local network, and send information about all detected IP addresses to the server. In addition, during the experts' observations, the backdoor was fitted with new modules for stealing information contained in KeyChain; data from messaging apps WeChat, QQ, and Telegram; and Safari and Chrome browser history.

Instead of using 0-day vulnerabilities, the operators of this campaign, which the researchers call TwoSail Junk, exploited 1-day vulnerabilities, i.e. recently discovered probems that have only recently been patched in the latest operating system updates. This means that iOS 12.1 and 12.2 users are at risk (the problem affects models from iPhone 6s to iPhone X).

In addition, analysis of the infrastructure related to iOS implant distribution revealed a link directing to Android malware. According to the analysis, in late November 2019 this link was distributed through the Telegram channels winuxhk and brothersisterfacebookclub and Instagram posts with a message lure in Chinese.

This campaign was dubbed Operation Poisoned News; no targeting of specific users was detected, the threat actors attacked website visitors in general.

Specialists link the activities of TwoSail Junk to a larger Chinese hacking group called Spring Dragon also known as Lotus Blossom and Billbug (Thrip). In particular, this group is responsible for the creation of Lotus Elise and Evora malware.

APT name	Regions attacked	Operation start
PoetRAT attacks SCADA systems in Azerbaijan	Azerbaijan	February 2020

Security specialists reported a new malicious campaign against Azerbaijan's government agencies and industrial enterprises, during which attackers used the topic of coronavirus to infect networks with a remote access Trojan. Researchers say the malware is designed to attack SCADA systems used in the electricity sector, in particular wind turbine systems, whose manufacturer has not yet been identified.

The attackers send out malicious Microsoft Word documents that load a previously unknown Python-based Trojan called PoetRAT onto the attacked system. The malware got its name because of numerous references to William Shakespeare's sonnets.

PoetRAT is equipped with all the features specific to a RAT. It can steal confidential documents, keystrokes on the keyboard, passwords, and even images from web cameras; it also provides its operators with complete control over the compromised system.

The attacks began in February this year, and since then, researchers have recorded three waves. Some of the fake documents purported to be sent from Azerbaijani government agencies or from the Defense Research and Development Organization of India. Some files were called "C19.docx" and had no content.

The Visual Basic Script macro built into the document writes malware to disk in the form of the archive "smile.zip," which consists of the Python interpreter and the Trojan itself. The malware checks to see if it is running on a virtual machine and, if a sandbox is detected, it is automatically deleted from the system.

The threat actors monitored specific directories, which meant that they wanted to exfiltrate certain information on the victims. The attackers wanted to get a full picture of the victim by using a keylogger, browser credential stealers, and Mimikatz and pypykatz for further credential harvesting.

APT name	Regions attacked	Operation start
Gamaredon	Europe, Ukraine	March 2020

In March, security specialists came across an email with a malware attachment that used the Gamaredon group's tactics. Some of the emails used the coronavirus pandemic as a topic to lure victims into opening the emails and attachments. These campaigns targeted victims in European and other countries.

The case that the specialists found arrived through a targeted email that contained a document file (in .docx format). Opening the document starts a template injection technique for loading the document template from the Internet. The downloaded document template contains malicious macro codes, which execute a VBScript (VBS).

The downloaded document template (in .dot format) could differ slightly depending on each download. However, its Exif info or metadata remains consistent and shares the following details:

- Identification: Word 8.0
- Language code: Russian
- System: Windows
- Author: АДМИН (Russian; "administrator")
- Code page: Windows Cyrillic

As mentioned, the template contains a malicious macro, which exports VBS to execute itself. More specifically, it drops %USERPROFILE%\Documents\MediaPlayer\PlayList.vbs, which is hardcoded in the macro, and then executed in wscript.exe //b %USERPROFILE%\Documents\MediaPlayer\PlayList.vbs.

"PlayList.vbs" contains obfuscated codes, which it executes after decrypting the obfuscations. This particular behavior is a slight departure from previously reported attacks by Gamaredon, which did not use this technique.

In addition, Gamaredon continued its attacks against Ukraine and used an .rtf document with the CVE-2017-11882 vulnerability to execute further code instead of a malicious macro document like the group did in the past. Due to an improved anti-detection effect of template injection, there are only several antivirus reports on VirusTotal.

Gamaredon group uses a package that includes a custom Microsoft Outlook Visual Basic for Applications (VBA) project. This bundle of malicious code starts out with a VBScript that first kills the Outlook process if it is running, and then removes security around VBA macro execution in Outlook by changing registry values. It also saves to disk the malicious OTM file (Outlook VBA project) that contains a macro, the malicious email attachment and, in some cases, the list of recipients that the emails should be sent to.

Next, it relaunches Outlook with a special option, /altvba <OTM filename>, which loads the Gamaredon VBA project. The malicious code is executed once the Application.Startup event is received. The group has been using this module in three different ways to send malicious emails to:

- Everyone in the victim's address book

- Everyone within the same organization
- A predefined list of targets

The second tool discovered by security specialists is used to inject macros and references to remote templates into Office documents – Word and Excel. Both are designed to help the Gamaredon group spread further in already compromised networks.

The latest tools inject malicious macros or references to remote templates into existing documents on the attacked system, which is a very efficient way of moving within an organization's network, as documents are routinely shared among colleagues. In addition, thanks to special functionality that tampers with Microsoft Office macro security settings, affected users have no idea that they compromise their workstations whenever they open the documents.

Gamaredon Group (aka Primitive Bear) is a Russian threat group active since at least 2013. The group first borrowed tools for their attacks, but then started using their own malware. Their group's attacks target governments, law enforcement, and military organizations mostly in Ukraine.

APT name	Regions attacked	Operation start
Gorgon Group	Canada, Global	January 2020

Security specialists discovered a number of suspected Gorgon attack samples that used COVID-19 as their theme. Analysis revealed that the latest payloads were hosted on GitLab.

The title of the phishing email attachment is "CVOID19Relief.docx" and the content is related to COVID-19. Analysts found that the content was taken from the official Canadian government website about the COVID-19 credit policy. The victims of this attack are believed to mainly be located in Canada.

The attachment uses a template injection technique to run malicious .rtf documents. There are multiple Excel objects embedded in the .rtf document. These Excel objects carry malicious macro code. After running, they will read the content in the remarks and execute it. They will then download the office1.exe loader, which executes PowerShell.

Gorgon hosts malicious code in multiple repositories on GitLab. Each repository has multiple projects. Each project contains different malicious modules. The base project is responsible for calling other projects; observations revealed that there were cross-calls for projects. Experts believe that there may be a joint development model of multiple teams in the Gorgon group.

Some modules were found in the repositories:

- RT/RTA is remote control software Remcos.
- azr is stealing software AZORult, which will steal sensitive information saved in cryptocurrency wallets, instant messaging software, browsers, etc.
- The clp module is a Cryptojacking Trojan, which hijacks the user's clipboard and steals the user's virtual currency.
- Loki is the Lokibot stealing software.

In addition, the Aggah campaign has been upgraded and continues to be active. It is currently believed that Gorgon Group hackers are behind the Aggah campaign.

Security specialists observed that the new Aggah campaign involved the distribution of malicious Microsoft Office documents via malicious spam emails distributing a multi-stage infection to a target user's endpoint.

The final payload of the infection consists of a variety of RAT families such as:

- AgentTesla
- njRAT
- Nanocore RAT

Consistent with previous Aggah campaigns, this campaign also focuses on the use of pastebin[.]com for all its infrastructure needs. However, this campaign now utilizes multiple Pastebin accounts to host different stages of the attack.

The key components of the attack are:

- Stage 1: Malicious spam delivering documents with malicious macros.
- Stage 2: Malicious VBScripts used to instrument the actual attack.
- Stage 2A: Malicious .NET-based binaries for disabling security features on the endpoint.
- Stage 3: Malicious VBScripts and .NET-based injectors and RATs (final payload).

This new campaign, however, introduces a few key upgrades to the attack chain:

- Use of an additional .NET binary (and embedded VBScript and PowerShell scripts) to disable protection and detection mechanisms on the infected endpoint.
- Distribution of attack components (scripts and encoded MZs) across multiple free Pastebin accounts to modularize the attack infrastructure.
- Use of a new Pastebin PRO account to host all the final RAT payloads. This also indicates a move from the "hagga" to the "alphabets3" Pastebin account for continued operations (a pro account enables the attackers to modify the pastes and serve different malware at different points in time).

Gorgon Group (also known as Subaat) was first reported on in 2017, when they targeted government organizations in the UK, Spain, Russia, and the US. The members of the group are believed to be from Pakistan.

APT name	Regions attacked	Operation start
APT37	South Korea, Russia, USA, Global	March 2020

APT37 continued their malicious activities in Q2 2020.

The use of an attack lure with malicious Office macro code is still the most commonly used attack method of the SYSCON/SANNY Trojan in addition to the malicious behavior of disguising the macro code by modifying the font color, which is also characteristic of this group. The topic of the lure continues to include current events, especially the pandemic (COVID-19), as well as local hotspot events related to the Korean peninsula.

For example, in March 2020, the APT37 used the document title “Masks are only recommended for those who care of a person with suspected COVID-19 infection” as a decoy for the attack. In addition, during this time, there were decoys called “Kinzler Foundation for 2020 Tokyo Paralympic games” and a document in Russian whose topic was related to the North Korean policy in 2020.

The main malicious behavior of the latest attack macro code is to release a PE file and create a process for execution. The released PE file is a downloader Trojan. Its main function is to extract the URL from the command line parameters and perform a series of download, decompression and installation actions. The downloader also downloads a RAT to the victim computer, which connects to an FTP server to download a configuration file.

The RAT executes commands in the command line, collects information about the computer and a list of processes, and uploads the file “temp.ini” to the FTP server in encrypted form.

In May 2020, the hackers used a file disguised as a document by CISAC (Center for International Security and Cooperation), a research center at Stanford University; they distributed the document with the name “CISAC Discussions on Cyber and Nuclear Issues_May 13 2020_v4_ENG.”

CISAC is an institution for researchers conducting academic and policy-related research on international cooperation related to international peace and security, human rights, and nuclear issues.

Malicious document files are invisible when first viewed, which seems to be intended for encouraging the user to enable the blocked macro functions. When the macro's malicious behavior is over, it changes the font color and makes it visible, thereby reducing the user's suspicion.

The malicious macro included in the malicious document is configured to run automatically when the document is opened using Document_Open, and the built-in encoded malicious executable has the value 0xFF to execute through cmd and additionally download the malicious file. The generated zx.exe file runs the encoded C&C as an argument and additional files are downloaded and executed according to the infected system.

The downloaded file is in .cab format, which is unzipped using the built-in cmd expand program and the file “zx.bat” is executed.

The file execution order is as follows: ① zx.bat -> ② install.bat -> ③ xclientelv.dll -> ④ xclientsvc.dll.

When the final payload, xclientsvc.dll, is executed, it collects information from the infected system and sends it to the attacker; it can also download and execute additional malicious files.

In addition, the group distributed Korean documents (HWP) during domestic conferences. The malicious code was produced under the title of a dissertation and academic conference. It is believed that the author of the malicious code aimed at the submission period for summer papers in domestic Korean journals mainly from May to July.

The malicious documents had the following names:

- 2020_XXXX_초전도 논문.hwp [2020_XXXX_Superconductivity thesis.hwp)
- 학술대회.hwp [Conference.hwp]

The rest of the malicious actions were similar to the group’s previous attacks.

APT37 (also known as Group123, Reaper, ScarCruft, Geumseong121, Red Eyes, Ricochet Chollima, Venus 121, Thallium, Hermit, and KONNI) is a North Korean cyberespionage group active since at least 2012. The group primarily targets South Korea, but also Japan, Vietnam, Russia, Nepal, China, India, Romania, Kuwait, and other regions.

APT name	Regions attacked	Operation start
Naikon	Australia, Indonesia, Philippines, Vietnam, Thailand, Myanmar, Brunei	2015

May 2020 saw the discovery of a campaign by Naikon hackers that had been ongoing for five years. Their attacks targeted government entities in Australia, Indonesia, the Philippines, Vietnam, Thailand, Myanmar, and Brunei.

Naikon APT used a new backdoor called Aria-body. The researchers said the aim of the group was to conduct reconnaissance and espionage against the governments of targeted countries.

The Aria-body RAT can create and delete files and directories, take screenshots, search files, gather file metadata, and collect information about the operating system and location. Some of recent Aria-body variations also included functionality such as keylogging and loading of extensions. In addition to exfiltrating all collected data to the C&C server, the backdoor is capable of executing other commands.

As the initial attack vector, Naikon APT sent out emails with malicious attachments to highest-level government entities as well as civil and military organizations. Once opened, the files installed spyware, which sent confidential data to C&C servers.

In a recent attack, Naikon APT purported to be the representatives of a foreign embassy. The threat actors downloaded the Aria-body backdoor to victim systems; the malicious emails contained an RTF file with the RoyalBlood exploit builder, which installed a loader (intel.wll) in the Startup folder (% APPDATA%\Microsoft\Word\STARTUP).

Naikon (also known as Camerashy and Hellsing) is a threat group that has focused on targets around the South China Sea since 2012. The group has been linked to the Chinese People's Liberation Army's (PLA) Chengdu Military Region Second Technical Reconnaissance Bureau (Military Unit Cover Designator 78020).

APT name	Regions attacked	Operation start
Patchwork	South Asia	January 2020

Since January 2020, security specialists have monitored the threat group Patchwork, which has used the BackConfig malware. The group's victims include government and military organizations in South Asia.

The initial infection occurs via a Microsoft Excel (XLS) document delivered via compromised legitimate websites, for which the URLs are most likely shared via email. The documents use Visual Basic for Applications (VBA) macro code which, if enabled by the victim, starts an installation process consisting of multiple malicious components.

In nearly all cases, the threat actors used malicious documents that required user interaction and it was only once in the past serveral months that the group used exploits to avoid involving the user in any of the installation stages.

BackConfig has various features, including the ability to gather system and keylog information and to upload and execute additional payloads. The latest versions contain modular components making it easier to update and reuse the code.

Specialists say that the malware sample contains some static artifacts including self-signed digital certificates used to sign an executable purporting to be the software of California-based Foxit Software Incorporated.

The Indian hacking group Patchwork (also known as Dropping Elephant, Chinastrats, APT-C-09, Monsoon, Confucius, Viceroy Tiger, EHDevel, Hangover, ZINC EMERSON, and Manul) has been active since at least 2015 and has been attacking organizations in industries connected with diplomatic missions and government entities for the purposes of espionage and information theft.

APT name	Regions attacked	Operation start
Tropic Trooper	Taiwan, Philippines, Vietnam	2018

May 2020 saw the discovery of a malicious campaign, ongoing for several years, in which the threat group Tropic Trooper uses the USBferry malware to conduct spear-phishing attacks against physically isolated networks of Taiwanese and Philippine military organizations, navy agencies, government institutions, military hospitals, and even a national bank.

According to the experts, USBferry can perform various commands, maintain stealth in environments, and steal critical data through USB storage. The campaign started as early as 2018, but analysis has shown that USBferry attacks have been tacking place since 2014.

During their analysis, the researchers discovered three versions of USBferry with different variants and components.

The first version has a small component, TROJ_YAHOYAH. The malware tries to check if the target machine has a USB plugin and copies the USBferry installer to the USB storage. The activities vary in target environments; some execute commands, source target files or folder lists, and copy files from physically isolated hosts to compromised hosts.

The second version has the same capabilities as the first one and combines components into one executable. This version also changes the malware location and its name to UF, an abbreviation for USBferry.

The third version retains the previous versions' capabilities and improves its stealth in the target environment by residing in the rundll32.exe memory.

Tropic Trooper has recently changed the way it uses USBferry in its attacks. The group achieves infection by employing the USB worm infection strategy and ferrying a malware installer via USB into an air-gapped host machine. The malware checks for network connectivity; if it finds that the network is unavailable, it tries to collect information from the target machine and copy the collected data to USB storage. This way, the USB exfiltrates information and sends it back to the C&C server.

According to new findings, Tropic Trooper is behind a phishing campaign apparently aimed at collecting data about Vietnamese government officials amid an ongoing territorial dispute between China and Vietnam.

The hackers try to trick Vietnamese government officials into clicking on malicious Microsoft Excel documents attached to emails purportedly detailing festivities for Vietnamese holidays. Targeted individuals appear to be located in Da Nang, Vietnam, near a collection of landmasses in the South China Sea known as the Paracel Islands. The area is one of the most hotly contested regions of the South China Sea, with Beijing claiming ownership of much of the waterway.

The malicious Microsoft Excel documents attached to the message are capable of infecting victims with malware similar to KeyBoy and ExileRat, which steal files and collect system information from victim computers.

Tropic Trooper (also known as Pirate Panda, APT23, KeyBoy, and BRONZE HOBART) targets government, military, healthcare, transportation, and high-tech industries in Taiwan, the Philippines, and Hong Kong and has been active since 2011. The group was reportedly using spear-phishing emails with weaponized attachments to exploit known vulnerabilities. Primarily motivated by information theft and espionage, the group has also been seen adopting different strategies such as fine-tuning tools with new behaviors and going mobile with surveillanceware.

APT name	Regions attacked	Operation start
Mikroceen	Kazakhstan, Kyrgyzstan, Uzbekistan, Tajikistan	December 2018

Experts at Avast and ESET, analyzed a Trojan that was used by an unknown Chinese APT, which spied against undisclosed companies in the telecommunications and gas industries as well as a government entity in Central Asia. The analysts named this campaign Mikroceen.

In their operations, the threat group used backdoors to gain permanent access to the corporate networks of its victims. Based on the obtained data, the researchers believe that the same group was involved in other attacks described in reports such as Kaspersky's Microcin against Russian military personnel, Palo Alto Networks' BYEBY against the Belarussian government and Checkpoint's Vicious Panda against the Mongolian public sector; the group has been active since at least 2017.

The experts support this theory by the fact that the hackers used Gh0st RAT, which has long and frequently been employed by Chinese APTs. In addition, the analysts discovered clear similarities in the codes of the malware the hackers used.

The analyzed backdoors enabled the hackers to manipulate files (move, read, delete, check existence), manipulate processes and services, execute console commands, and cover their presence in the system. Some commands may have instructed the Trojan to exfiltrate the data of the victim companies to the C&C server. Infected devices could also be commanded by a C&C server to act as a proxy or listen on a specific port on every network interface.

APT name	Regions attacked	Operation start
APT15	-	December 2019

In mid-May, security experts identified three samples recently uploaded to VirusTotal that shared code with older APT15 implants. The experts named this new family of samples Ketrum due to the merger of features in the documented backdoor families Ketrican and Okrum.

The new samples continue APT15's strategy of using a basic backdoor to gain control over the victim's device, so that the operator can then connect to it and run commands manually to conduct further operations.

All three samples contacted the same C&C server and appear to have been used in two different time periods, judging by the PE timestamps and VirusTotal upload date.

The Ketrum 1 sample was uploaded to VirusTotal in December 2019. This version registers itself as a "WMI Provider Host" service if it is able to obtain SeDebugPrivilege; otherwise it creates an entry in the Startup directory.

This sample incorporates many features of Okrum; however, it abandons more advanced Okrum features such as offering a reflective injection via an export and the use of hashes to receive command IDs.

Ketrum 2 seems to have been built for minimalism. Unlike the Ketrican variant, Ketrum implants no longer try to weaken the system's security configurations. In previous implants, PowerShell was used for this purpose.

The malware first collects basic system information to track the infected endpoint and then sends it to the C&C server together with a hash of the system info.

APT15 (also known as Ke3chang, Mirage, Vixen Panda GREF, and Playful Dragon) is a cybercriminal group believed to be based in China. The threat actors have been active since at least 2010. Their aim is cyberespionage against diplomatic organizations in Europe.

APT name	Regions attacked	Operation start

Chimera	Taiwan	2018

A new hacking group was discovered; it attacked multiple companies in Taiwan's superconductor industry throughout 2018–2019. During their investigation, security specialists dubbed this threat Chimera. Chimera stands for the synthesis of the hacker tools that the specialists observed the group use, such as the skeleton key malware that contained code extracted from both Dumpert and Mimikatz — hence Chimera.

Due to the use of this malware, the campaign was named Operation Skeleton Key. The main objective of these attacks was exfiltration of intellectual property, such as documents on integrated circuits (IC), software development kits (SDKs), IC designs, source code, etc.

These attacks are likely a result of attempts by competitors (or possibly even nation-states due to the advanced nature of the attacks) to gain a competitive advantage.

Some conclusions the specialists made during their investigation into Chimera's malicious activities:

1. SkeletonKeyInjector. This malware contained code extracted from both Dumpert and Mimikatz and was used as an account manipulation tool. The malware altered the New Technology LAN Manager (NTLM) authentication program and implanted a skeleton key to allow the attackers to log in without the need of valid credentials. Once the code in memory was altered, the attackers could still gain access to compromised machines even after password resets. The attackers then used the skeleton key to freely move laterally to other machines in the same domain. There was no difference when compared with legitimate login activity, nor was legitimate user login activity hindered. These factors helped mask the attackers' malicious activities.
2. Counterfeit Google RAT. The attackers utilized Cobalt Strike as their main RAT. The mutated backdoor replaced and then masqueraded as a Google Chrome Update to confuse users. In order to further mask malicious activity and make attribution difficult for defenders, the attackers placed most of the C&C servers on Google Cloud Platform.
3. ChimeRAR. Chimera used an old and patched version of RAR modified for data exfiltration.

APT name	Regions attacked	Operation start
SideWinder	Pakistan	2020

In May 2020, security specialists observed several malicious LNK samples related to the COVID-19 pandemic, which had the following names: "Policy Guidelines for Online Classes.lnk," "Pak_Army_Deployed_in_Country_in_Fight_Against_Coronavirus.pdf.lnk," and others. Once the victim launches these samples, the LNK file will download a malicious script from a remote server for execution. The malicious script will release a decoy document appearing normal to confuse the victim and continue to obtain the second stage of malicious script execution from the remote server.

During the second stage, the malicious script will deploy relevant malware on the victim's computer, load the final remote Trojan to control the victim's machine, and steal sensitive information.

It was found that SideWinder was behind the malicious actions. The APT is believed to be based in India and its earliest attack is traced back to 2012. The group focuses on cyberespionage against military targets in countries in South Asia, such as Pakistan.

APT name	Regions attacked	Operation start
Charming Kitten	Switzerland, USA	April 2020

The hacking group Charming Kitten is suspected of attempting to compromise the servers of the World Health Organization with the help of malicious emails allegedly sent on behalf of the British Broadcasting Corporation and the American Foreign Policy Council (AFPC).

Sources say that the attacks began on April 3 this year and were aimed at stealing passwords and two-factor authentication codes for the accounts of WHO employees for subsequent malware infection of the organization's servers. The phishing emails contained a shortened Google link to a malicious domain.

The cyberattacks could be the work of the Iranian APT Charming Kitten, as indicated by the domains mobiles.identifier-services-session[.]site, sgnldp[.]live, and the bitli.pro service, which were seen in this group's previous attacks.

In addition, researchers at Google Threat Analysis Group discovered a phishing operation targeting a Donald Trump campaign staffer. According to the Trump campaign, the hacking attempt was noticed, but was not successful.

The Iranian threat group Charming Kitten (also known as Phosphorus, APT35, Group 83, and Parastoo) has been carrying out attacks since at least 2013. The group focuses on individuals of interest to Iran who work in the fields of academic research, human rights, and media, with most victims located in Iran, the United States, Israel, and the UK. The hackers usually try to gain access to private email and Facebook accounts and sometimes establish a foothold on victim computers as a secondary objective.

APT name	Regions attacked	Operation start
Cycldek	South-East Asia	2018

Cybersecurity experts discovered a Trojan called USBCulprit, created by the hacking group Cycldek. This malware is designed to steal data from corporate networks and gives the threat actors the capability to reach air-gapped devices, i.e. those that are physically isolated and not directly connected to the Internet. According to the specialists, the malware has been active since 2014, with new samples emerging in 2019.

Post 2018, most of the attacks have been initiated with a phishing email that contains a politically-themed RTF document. Opening it results in the exploitation of known vulnerabilities and download of malicious payload, NewCore RAT. This malware, in turn, downloads the USBCulprit Trojan, which scans paths to executable files, collects documents with certain extensions and then transfers them to USB drives connected to the system. This suggests that the malware is designed to reach air-gapped machines, to which information can only be transferred through removable media.

When a USB drive infected with USBCulprit is connected to a computer, the Trojan will either exfiltrate stolen data to it or, inversely, take data that was saved by a USBCulprit copy on an isolated computer (depending on the configuration and commands received). The malware is capable of targeting specific files, including those last modified, and can also extend its capabilities. For instance, its later versions can execute files from connected USB drives.

Cycldek (also known as Goblin Panda and Conimes) is a threat group that has been active for the most part of the past decade and has historically had motives related to information theft and espionage aligned with Chinese interests. The group's targets are primarily military, energy, and government organizations located in South/South-East Asia with a focus on Vietnam.

APT name	Regions attacked	Operation start
Higaisa	China	December 2019

In the spring of 2020, multiple attacks conducted by Higaisa since 2019 were discovered.

In December 2019, phishing emails with a malicious .scr attachment and holiday greetings were sent out. Their subjects were: "Happy new year 2020" and "2020 New Year Wishes For You." Opening the attachment shows an image with greetings (Happy-new-year-2020.jpg) to distract the victim. In addition, two other files are loaded: "Rekeywiz.exe," "Duser.dll." During the launch of "Rekeywiz.exe," the DLL side-loading technique is used and in addition to loading a legitimate file, the malicious "Duser.dll" is loaded. The C&C address is RC4-encrypred. The attackers create an identifier based on the CRC32 value of the disk serial number and send it to the C&C server. The server returns the payload, which comprises an infostealer and a modified version of Gh0st RAT. The infostealer is used to collect information (about the system, network, processes, and files) and send it to the C&C server. Three different versions of Gh0st RAT were found; one of them had a single function of loading plugins that are used for the implementation of the required functionality.

Another file with greetings called "邀请函.doc" was later discovered. It was created using the popular builder Royal Road RTF, which exploits the CVE-2018-0798 vulnerability. Its exploitation results in the loading of a dropper, which is used to launch two encrypted files "360ShellPro.exe" and "FileSmasher.exe." Similar to the case described above, legitimate "360ShellPro.exe" transfers control to malicious "FileSmasher.exe." Communication with the server follows the same scheme.

In March, Higaisa used the COVID-19 topic for its attacks. Security researchers discovered a file called "20200308-sitrep-48-covid-19.pdf.lnk." When it is opened, the shortcut and a file called "CertUtil.exe" (under the name of "msoia.exe") are placed in a temporary folder. Next, the Base64-encoded payload is decoded using msioa.exe. The decoding results in a CAB archive, which contains several files, one of which is JScript. This script performs a series of actions that result in the execution of intermediate files, the use of DLL side-loading technique, and the final payload PlugX. The first request to the C&C server still passes the victim's identifier (SuperFastHash of the disk serial number and computer name).

On May 29, another campaign by the group was detected, which started on May 12. The threat actors used a malicious LNK file bundled within an archive file, which was most likely distributed via phishing emails. Two files were discovered: "CV_Colliers.rar" and "Project link and New copyright policy.rar." The first archive contains an .lnk file disguised as IETLS exam results; the second archive seems to target product teams that use zeplin.io. The launch of the .lnk in the command line results in the execution of the same command as in the March campaign, except that some of the files have different names. The final payload was not installed.

Higaisa is an APT group based in South Korea. It has been active since at least 2016. Their attacks mostly target organizations whose activities are related to North Korea (governments, human rights societies, trade organizations). In addition, the group's victims have been identified in China, Japan, Nepal, Singapore, Russia, Poland, and Switzerland.

APT name	Regions attacked	Operation start
Darkhotel	China, Japan	March 2020

In April 2020, a campaign attributed to DarkHotel was discovered. The attacks started in March 2020 and targeted Chinese government agencies. In particular, the victims included Chinese agencies in Italy, the UK, Pakistan, Kyrgyzstan, Indonesia, Thailand, the UAE, Armenia, North Korea, Israel, Vietnam, Turkey, Malaysia, Iran, Ethiopia, Tajikistan, Afghanistan, Saudi Arabia, and India.

More than 200 VPN servers were compromised during this campaign. The hackers used a zero-day vulnerability in Sangfor SSL VPN servers, which was assigned the number SRC-2020-281. Servers running

firmware versions M6.3R1 and M6.1 were vulnerable. The user's launching of a VPN client triggers a process, during which an update specified in the configuration file is downloaded from the server. The attackers exploited the vulnerability, gained access to the configuration file, and replaced a legitimate update with a program with the same name, "SangforUD.exe," which had a built-in backdoor.

Once it is installed on the victim machine, the backdoor sets up communication with the C&C server and downloads shellcode, which collects basic information: OS version, MAC/IP, list of processes, and installed software. Next, it installs .dll components to ensure persistence. The attackers use the DLL search order hijacking technique to install the main backdoor component. This component decrypts the file "sangfor_tmp_1.dat" obtained through cloud storage. This file is then used to execute commands received from the C&C server.

May 2020 saw the discovery of a previously unknown malicious program called Ramsay, which can steal data from physically isolated systems and is attributed to DarkHotel. One of the discovered samples was uploaded to VirusTotal (VT) from Japan. Multiple vectors were used to distribute Ramsay:

- Ramsay v.1 is distributed through a malicious document with an exploit for the CVE-2017-0199 vulnerbaility. The document delivers an initial script that extracts the Ramsay agent masquerading as a JPG image with a Base64-encoded executable. This version was uploaded to VT with the names *test* and was significantly simpler than the second version, which gave rise to the assumption that the threat actors were testing this tool.
- Ramsay v.2 was uploaded to VT masquerading as a 7zip installer. This version was more complex and supported persistence and evasion techniques. It also has Spreader component, which is used to infect executable files located on disks, including removable drives, in order to eventually reach isolated systems.
- Ramsay v.2b. In addition, the distribution of another malicious document with an exploit for the CVE-2017-11882 vulnerability was detected. Its exploitation results in a Ramsay installer being dropped. This version has the same functional capabilities as version 2a, the difference being that it does not use the Spreader component.

Based on its version, Ramsay implements various persistence mechanisms of different complexity. The following mechanisms were detected: AppInit DLL registry key; Scheduled Task via COM API; Phantom DLL Hijacking.

Ramsay has the following functional capabilities: collection and hidden storage of files; command execution (file execution, dll load, batch execution). Ramsay cannot have network-based C&C communication, which is why it scans network shares and removable drives for potential control files. These files are parsed for the presence of a marker specific to the control file format.

DarkHotel is a cybercriminal group active since 2007 and believed to be based in North Korea. The group's primary targets are luxury hotel guests and political organizations mostly in North-East Asia. The aim of the group's attacks is to collect confidential information and carry out cyberespionage.

APT name	Regions attacked	Operation start
Turla	Europe	December 2019

In November 2019, security researchers detected a new HTTP status-based Trojan that had the same code base as CompFun, discovered earlier. Compfun had earlier been attributed to Turla, which is why the new Trojan was linked to this group. The discovered attacks target European diplomatic entities and spread a dropper purporting to be a VISA application. The legitimate application is kept encrypted inside the dropper along with 32- and 64-bit payload. When the dropper is opened, the user is shown a message urging them to run the file as administrator. The corresponding version of the Trojan is then dropped to the victim machine and the timestamp is changed.

During initialization, the malware collects system information, checks whether it is running in a virtual environment, identifies what antivirus tools and monitoring programs are installed, decrypts the configuration file, from which it extracts the RSA public key, ETag, and IP addresses to communicate with the C&C server. The first GET request sent contains an ETag "If-Match" header that is built using data from its decrypted configuration. This approach helps the server ignore all requests that are not sent from its intended targets if they don't have the required ETag value.

Through HTTP status codes, the attackers encode the following commands: send collected data to the server; launch the received commands to execute; install/delete files; create and transfer system fingerprints; transfer files/directory contents; propogate to USB devices; and collect information about network resources. It also supports keylogging functionality and can take screenshots.

Turla is a Russian-speaking cybercriminal group believed to have been active since 2007. The main goal of Turla's attacks is to steal information from diplomatic, government, military, educational, research and pharmaceutical organizations.

APT name	Regions attacked	Operation start
Mustang Panda	Europe	December 2019

Security specialists discovered a recent malware sample that used the DLL side-loading technique with a legitimate binary to load a threat.

This particular sample has a very small DLL that loads an encrypted file, which after being decrypted consists of a sample of the PlugX Trojan. This technique, and final threat together, consists of one of the most common TTPs among some APT groups generally of Chinese origin.

The binary consists of an installer, which drops a legitimate binary vulnerable to DLL side-loading in the folder C:\ProgramData\AAM Updatesnnk, as well as the small DLL, which acts as a loader for the final threat, and the binary file, which consists of the encrypted PlugX sample.

After deploying the three files, the installer runs the legitimate binary, causing the final PlugX threat to be loaded by it. In this case, the legitimate vulnerable binary is part of Adobe Suite, which will load any library named "hex.dll" that is next to the executable. The main function of the library is to call a function that checks the existence of a .dat file, which is hardcoded (adobeupdate.dat in this case), loads it, extracts the first string of the binary, and uses it as a XOR key to decode the rest of the file, which consists of the final threat.

When it finishes deciphering it, it loads the malware into memory, makes a "Memprotect" to make it executable and launches its logic from byte 0 of the binary. Opening the binary as a shellcode will show how the first bytes have been modified into a routine that jumps to a code zone, consisting of a PE loader.

After loading the IAT and leaving everything ready as a normal executable, this threat decrypts its own configuration, which is encrypted in XOR in the .data section of the binary. This time the decryption key is hardcoded in the binary, and is the string "123456789."

After decrypting its configuration, it contains the folder where the binary must be installed, a XOR key that will be used to encrypt its traffic, and a list of up to four domains or the IP addresses of C&C servers together with the port to be used. Generally the four C&C elements consist of the same domain repeated four times or two domains repeated twice each.

After their analysis of the threat actors' actions, the specialists concluded that the group Mustang Panda was behind these actions.

Mustang Panda (also known as HoneyMyte, Red Lich, Temp.Hex, and BRONZE PRESIDENT) is a Chinese threat group active since at least April 2017. Its main targets are governmental and non-governmental organizations and national minorities.

APT name	Regions attacked	Operation start
TA410	USA	July 2019

Between the summer and November of 2019, the TA410 threat group conducted campaigns against US utilities. The threat actors sent out emails with malicious attachments to install LookBack or FlowCloud malware.

Between July and September 2019, the attackers distributed PE files as attachments, which were used to install the FlowCloud malware. The subject line was "PowerSafe energy educational courses (30-days trial)." In November, another FlowCloud mailout took place purporting to be from ASCE (the American Society of Civil Engineers). This attack involved an attachment in the form of a malicious document with a macro. The mailouts involved domains masqueraded as those of educational courses of energy organizations. FlowCloud is a modular C++ payload named after PDB paths and developed in at least 2016. It can access the keyboard, mouse, screen, installed applications, services and processes with the ability to transfer collected information to the C&C server using a custom protocol.

In addition, July 2019 saw another mailout purporting to be by NCEES and Global Energy Certification. A malicious Word document with a macro was used as an attachment. Its launch triggered a series of actions resulting in the LookBack malware being installed, which has functionality similar to that of FlowCloud.

TA410 is a Chinese threat group specializing in espionage and believed to have been active since 2016. It is notorious for its attacks against US utilities. The group engages in phishing and social engineering. Among its unique tools are LookBack and FlowCloud. Overlaps have been found between TA410 and APT10, but it has not yet been established whether they are related or if TA410 disguises itself as APT10.

APT name	Regions attacked	Operation start
OceanLotus	India, Vietnam, Bangladesh, Indonesia, Nepal, Myanmar, Malaysia, China, South-East Asia	Late 2015

On April 28, 2020, security researchers published a report about a campaign called PhantomLance, which targeted Android users. According to the researchers, about 300 infection attacks have been observed since 2016 in India, Vietnam, Bangladesh, Indonesia, Nepal, Myanmar, and Malaysia. This campaign started in late 2015, when the first C&C server was registered.

Analysis revealed multiple versions of PhantomLance. Despite appearing at different times and increasing complexity with each version, they are similar in functionality.

The main purpose of PhantomLance is to gather sensitive information from victim devices. To do so, the malware may obtain root privileges on the target device and therefore be able to transfer geolocation data, call logs, SMS messages, list of installed applications, and full information about the infected device to its operators. Moreover, its functionality can be extended at any time by downloading additional modules from the C&C server.

To distribute PhantomLance, the threat actors seem to have used mainly Google Play. It has also been found in third-party repositories, but for the most part they are only mirrors of the official Google app store. The researchers say that apps infected with a version of the Trojan started appearing on the store

in the summer of 2018. The malware was found hiding in utilities for changing fonts, removing ads, system cleanup, and so on.

The first versions of the apps uploaded to Google Play did not contain malicious code. They were published on the official app store because they did not contain anything suspicious; later versions, however, were updated with malicious code. In almost every case of malware deployment, the threat actors tried to build a fake developer profile by creating a GitHub account that only contained a fake end-user license agreement (EULA). This type of behavior has already been detected in the OCEANMOBILE campaign.

While tracking PhantomLance's infrastructure, which dated back four years, the researchers noticed that expired domain names had been extended in late 2019 – early 2020. This suggests that the infrastructure might be used again in the future.

In May 2019, Antiy Labs published a report, in which the specialists described an Android malware campaign, claiming it was related to OceanLotus APT. Links to malicious applications hosted on third-party websites, possibly distributed via SMS or email, were the main infection vector. Some sources say this campaign overlaps with PhantomLance despite multiple differences. The overlapping classes look quite similar and have the same functionality.

In a campaign that started in at least January 2020, the OceanLotus group sent out phishing emails related to the COVID-19 crisis. The emails were sent to the Chinese Ministry of Emergency Management and Wuhan government.

The first known instance of this campaign was on January 6, 2020, when the group sent an email with an embedded tracking link to China's Ministry of Emergency Management using the sender address lijianxiang1870@163[.]com and the subject 第一期办公设备招标结果报告 [Report on the first quarter results of office equipment bids].

Interestingly, one of the tracking links was in a domain that was used in December 2019 as a C&C server for the METALJACK phishing campaign, likely targeting countries in South-East Asia.

METALJACK is a malicious program that comes with a decoy document in Chinese containing information about COVID-19. When the krpt.dll loader is launched, one of its embedded resources, a decoy RTF document, is executed. In addition, shellcode is loaded, which contains the METALJACK payload. The shellcode performs a system survey to collect information such as computer name and username and then sends this information to the C&C server. If the request is successful, the malware loads the METALJACK payload into memory.

Our system for detecting malicious infrastructures continues to identify malicious hosts. For instance, the system recorded Cobalt Strike framework C&C servers used by OceanLotus. Detected hosts include: hosts that the group has already used, hosts with which malicious files from various sandboxes establish network connection, and hosts where no malicious activity has been observed but that can be assumed to belong to OceanLotus with medium confidence. The files that establish network connection include documents of Vietnamese origin and the KerrDown loader.

OceanLotus, also known as APT32, APT-C-00, SeaLotus, Sinh Tử Lệnh, Cobalt Kitty, and SectorF01, has been active since late 2009 and is believed to be based in Vietnam. The group attacked Vietnamese bloggers and dissidents and launched targeted attacks on industrial and government entities in Vietnam, Cambodia, China, Laos, the Philippines, Germany, and the United States. Apart from phishing emails, OceanLotus carries out watering hole attacks.

APT name	Regions attacked	Operation start

MuddyWater	Pakistan, Turkey, USA, Canada, Spain, Germany, UK	2020

On April 8, 2020, researchers at ClearSky published an article in which they said that a website with open directories, http://advanceorthocentex[.]com/wp-includes/, was used by the group MuddyWater as a C&C server. It was found that it hosted obfuscated log files of victim machines' communication with the C&C server and a list of IP addresses used to control the C&C server.

A Base64-encoded file called "kcxyErMOox.txt" contains a list of communications received by the C&C server. These communications contain information about victim devices, for example: *Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; WOW64; Trident/5.0; rv:9.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; .NET4.0C; .NET4.0E; InfoPath.2; BOIE9;ENUS)admin:USER-PC:USER-PC:Windows (32-bit) NT 6.01 <IP Address>.*

Analysis of logs revealed that the victims were located in Pakistan, Turkey, the US, Canada, Spain, Germany, and the UK. Some of the addresses belong to Iranian Internet service providers, which most likely suggests that the tools may have been tested. The researchers believe that the threat actors use Linux X11 (The X Window System) as their operating system and Firefox browser. Based on User Agent patterns, the researchers made an assumption that the IP addresses 103.205.140[.]177, 173.205.92[.]72, 24.244.207[.]36, and 87.113.216[.]57 belong to the group.

MuddyWater is a cybercriminal group active since 2017 mostly in the Middle East. The group's main activity is cyberespionage in pursuit of Iran's interests. The threat actors' targets are government agencies and organizations, military entities, and petrochemical and telecommunications companies. The targets are located in Saudi Arabia, the UAE, the US, Israel, Iraq, India, Jordan, Egypt, Tunisia, Turkey, Tajikistan, Iran, Belarus, Russia, Uzbekistan, Georgia, and Pakistan. Most of the victims are in the Middle East.

APT name	Regions attacked	Operation start
Chafer	Saudi Arabia, Kuwait	May 2018

On May 21, 2020, security researchers released a report about a campaign that the group Chafer started in 2018. The campaign targeted air transportation and government organizations in Kuwait and Saudi Arabia with the aim of data exfiltration. The campaign started approximately on May 30, 2018 and ended on December 13, 2019.

According to the researchers, the first signs of compromise were suspicious files and PowerShell commands that executed some Base64-encoded code specific to the Metasploit framework. The threat actors may have used documents with malicious macros as an attack vector.

Once the victims were compromised, the attackers used reconnaissance tools for network scanning and credential gathering as well as CrackMapExec (a utility for user enumeration, network share listing, credential harvesting, and so on). This arsenal of tools helped the attackers move laterally inside the network. Several methods were observed for this operation: either the use of psexec for remote service installation or the use of RDP.

Once the attackers gained a foothold inside the company's perimeter, they started installing custom modules: a modified Plink installed as a service and a backdoor, which was also executed as a service on some machines. The attackers created a user account on the victims' machine and performed several malicious actions inside the network using that account.

The attackers maintained constant communication with the compromised system, either through tools with proxy functionalities or through their own backdoor. Interestingly, the C&C address was passed as a command line argument (both for some of the proxy tools and for the backdoor itself).

The attack against organizations in Saudi Arabia started no later than January 8, 2019 and continued up until February 17, 2019. On one device the researchers discovered a RAT in the Download directory. It appears that the RAT was executed twice and was downloaded manually by the user.

Internal network reconnaissance was performed using the "etblscanner.exe" tool. The researchers noted the use of three different RAT components, which, according to the timeline, were not used at the same time. One of those components, "snmp.exe," was also present on some of the victim devices in Kuwait under the name "imjpuexa.exe," linking these attacks to the same threat group.

This campaign involved both private and publicly available tools such as Sysinternals, psexec, Safetykatz, Metasploit, CrackMapExec, nbtscan tool, and EternalBblue scanner. The private tools included a modified version of Plink, proxy tools, and the group's custom backdoor Remexi.

The Chafer group has been active since at least 2014. The threat actors' main objective is to collect information that allows them to track targets related to Iran's national priorities or use them as additional accesses to facilitate future campaigns. The group's activities are concentrated in the Middle East. Chafer has prioritized the telecommunications sector, with additional targeting of the travel industry and IT firms that act as contractors of the companies in which the group is interested.

APT name	Regions attacked	Operation start
OilRig	South Asia, Middle East	October 2019

According to researchers at Symantec, APT34 continued to be active in attacking telecommunications companies in South Asia in April 2020. During the campaign, the threat actors used post-exploitation frameworks and tools such as Covenant, Cobalt Stike, Metasploit, and Mimikatz. In addition, the group used legitimate tools such as Plink, Bitvise, and Bitsadmin. The threat actors used phishing emails to gain initial access. According to the researchers, the campaign's main aim was to steal user credentials and gain access to database servers using the obtained credentials.

One of the malicious files in the first stage of this campaign is a file called "proposal_pakistan110.chm:error.html." It is essentially a CHM file that which includes an alternative data stream to hide its payload, which is executed when the file is launched. The researchers say that the file "GRUNTStager.hta," which is a Covenant framework stager, was executed at approximately the same time.

Some sources say that the threat actors may have been present in the network of one organization starting in October 2019. The first activity was observed on October 11, 2019, when a malicious PowerShell command was executed to install a CobaltStrike Beacon module. Later, the attackers attempted to download "CSIDL_APPDATA\a8f4.exe" from the C&C server via the bitsadmin utility. In addition, the files "revshell.exe" "printers.exe," and "msf.exe" were downloaded to the directory csidl_system_drive. The threat actors then executed a PowerShell command that launched "msf.exe," which is Metasploit for ensuring persistence in the system.

The group's activities resumed on February 6, 2020, when a PowerShell command was executed, following the execution of the w3wp.exe process, which is used to serve requests to a web application. The researchers say that this may indicate that the attackers used a webshell on the compromised machine. This PowerShell command is used to search for files similar to web.config. For each file found, it

extracts username and password information where possible, decrypting it using the aspnet_regiis.exe utility. These credentials may be used to access organizational resources such as SQL servers.

On March 11, the attackers attempted to connect to a database server via PowerShell, presumably using credentials they had stolen. The attackers also used an SQL command to retrieve information about the version of the database server, presumably to test the credentials and connectivity.

In mid-May, our system for detecting malicious infrastructures identified the domain edfrnancapital[.]com. We believe with medium confidence that this domain has been registered by OilRig. The domain resolves to 45.88.3[.]57.

On May 22, 2020, a file called "Administrator Notification_ Redirecting email with malware.msg" was uploaded to the public sandbox ANY.RUN. This file is an Outlook system notification. The notification contains the original email and an attachment. The email was sent to the company Evoqua.com together with an HTM file, which when opened connects to edfrnancapital[.]com.

In addition, the domain evvellix[.]com, which was created on April 14, 2020, also points to this IP address. The NS records of this domain, like with edfrnancapital[.]com, point to justforsaving[.]xyz, which has been resolving to the IP address 45.88.3[.]57 since May 7.

In addition, since February 28, 2020, the NS records of justforsaving[.]xyz specified onefilecluod[.]xyz. A file called "Fairfield Inn & Suites New York Staten Island Sales Review.eml," which was uploaded to ANY.RUN on February 28, 2020, connected to that domain. The file is a phishing email with an HTM attachment, purporting to be sent by the OneDrive team. When the attachment is opened, connection with onefilecluod[.]xyz/login is established. Since at the time of the research the website was disabled, it was not possible to check its contents. However, this can indicate an attempt to steal OneDrive credentials. The phishing email was sent from an email address belonging to an employee of Fairfield Inn, a hotel chain.

During their analysis, Group-IB specialists discovered a list of compromised credentials, such as email accounts, passwords, and IP addresses. The list of email acconts includes users at the following companies:

- baschmann.com
- hollandandsherry.com
- fontanametalsales.com
- compowercorp.com
- emergi-cash.com
- racky.com
- idctechnologies.com
- jeffshapirolaw.com
- goldsteinlawpc.com
- continentalcoal.com

OilRig (also known as APT34) has been active since late 2015. The group is based in Iran and is believed to be linked to the Iranian government. The threat actors mainly target the banking sector, airlines, educational institutions, government entities, and IT and telecommunications companies. The group had targets in Saudi Arabia, Turkey, Israel, Kuwait, Qatar, the US, the UAE, and Lebanon.

APT name	Regions attacked	Operation start

Operation In(ter)ception	Europe, Middle East	September 2019

Specialists at ESET reported about a new cyberespionage campaign against the aerospace and military industries in Europe and the Middle East. The threat actors' primary goal is espionage against key people in companies; in some cases it is money theft.

The campaign was dubbed Operation In(ter)ception based on a related malware sample named "Inception.dll." The campaign took place between September and November 2019.

The attacks were based on social engineering techniques: the threat actors posed as HR managers at aerospace and military companies (including Collins Aerospace and General Dynamics) and sent out messages about job offers on LinkedIn. Once contact with a victim was established, the attackers sent job offer–related documents that infected the company's networks with malware.

Besides malware, the attackers used the living-off-the-land tactic, abusing legitimate operating system tools and features. Several techniques were used to avoid detection, including code signing, regular malware recompilation, and impersonation of legitimate software and companies.

According to the investigation, the primary goal of the operation was espionage. However, in one of the investigated cases, the attackers attempted to monetize access to a victim's email account through a business email compromise (BEC) attack as the final stage of the operation.

While the specialists did not find strong evidence connecting the attacks to a known threat actor, they discovered several hints suggesting a possible link to the Lazarus group, including similarities in targeting, development environment, and anti-analysis techniques used.

APT name	Regions attacked	Operation start
InvisiMole	Eastern Europe	2019

Security specialists discovered a campaign by InvisiMole targeting the military sector and diplomatic missions in Eastern Europe. Its primary goal is cyberespionage.

InvisiMole has been active since 2013. The threat group's malicious actions were first detected in 2018, during their cyberespionage activities in Russia and Ukraine. The experts previously documented its two backdoors, RC2CL and RC2FM, notable for their extensive spying capabilities, but they did not know how these backdoors were delivered, spread, or installed on the system.

The experts discovered that InvisiMole collaborated with another threat group, Gamaredon. Gamaredon malware was used to infiltrate the target network and deliver the advanced InvisiMole Trojan to targets that were particularly interesting to the threat actors.

InvisiMole components are protected with per-victim encryption, which ensures that the payload can be decrypted and executed on the compromised machine only. In addition, using their upgraded toolset, the attackers employ the DNS tunneling technique for more reliable C&C communication.

APT name	Regions attacked	Operation start
Attack involving AcidBox	Russia	2017

In June 2020, information was released about previously unknown attacks targeting at least two Russian organizations in 2017. The attacks involved AcidBox malware for VirtualBox. The group behind this attack has not been identified.

The first known attacks against VirtualBox were conducted by the threat group Turla. The affected version was VBoxDrv.sys v1.6.2; the group exploited two vulnerabilities. While one of them was fixed in version 1.6.4, the second vulnerability remained. In 2019, security researchers discovered another group that used this unpatched vulnerability, which turned out be present in all VBoxDrv.sys versions up to 3.0.0. In particular, the 2017 attacks against Russian organizations involved an exploit that targeted version 2.2.0.

The attackers used the AcidBox malware. Several usermode DLLs and an unsigned kernelmode driver were discovered. The DLLs were created as security support providers (SSPs) and were used to load the main module. This module loads an unsigned malware driver via the VirtualBox exploit and waits for commands (loading of additional payloads or installation of new SSP DLLs) from other components that were not obtained.

The researchers believe that despite the exploitation of the same vulnerability, Turla is not associated with these attacks and the groups are not related.

APT name	Regions attacked	Operation start
Attack on governmental and private organizations in Australia	Australia	2019

In June 2020, Australian Prime Minister Scott Morrison reported a cyberattack against government entities and private companies. The attackers' targets were ministries, headquarters of industrial companies, political organizations, educational institutions, medical departments, suppliers of water, heat and electricity, as well as bodies responsible for the security of the country's infrastructure.

According to experts at the Australian Cyber Security Center (ACSC), the attack was carried out through the use of remote code execution vulnerabilities in affected versions of Telerik UI software, as well as deserialization vulnerabilities in proprietary Microsoft Internet Information Services (IIS) software, SharePoint 2019 software, and Citrix 2019 virtualization software solutions.

According to the experts, attacks on public infrastructures were unsuccessful, which is why the attackers switched to spear-phishing attacks and gained access to some systems. The criminals used compromised legitimate Australian web sites as C&C servers. First of all, management and control were achieved using web shells and HTTP/HTTPS traffic. This method made geoblocking ineffective and made it possible to mask malicious network traffic as legitimate.

There is a suggestion that that the malicious activities were supported by another government but it has not yet been confirmed which particular one.

APT name	Regions attacked	Operation start
APT30	Malayisia	2019

April 2020 saw the discovery of an attack by APT30, which had long been quiet.

In August 2019, a file named "AGENDA.scr" was uploaded to VirusTotal from Malaysia. This is an executable PE file for x86 packed with UPX. The icon of the sample matches that of a Microsoft Office document (in order to trick users). The resources contain another two encrypted objects.

The first file is written to the Microsoft Office templates folder (%APPDATA%\Microsoft\Windows\Templates\AGENDA.docx) and then run. This Office document, with the agenda for a Malaysian government meeting, is intended to attract the user's interest.

The second file is placed in the Startup folder %APPDATA%\Microsoft\Windows\Start Menu\Programs\Startup\WINWORD.EXE. The file is not run at the time of creation (instead, the attackers arrange for it to run at another time that will be less suspicious, such as after a restart). This is a NETEAGLE backdoor, which has been used by APT30 since 2008. The string NetEagle, which was found in the 2015 samples and gave its name to the whole malware family, has now been replaced with JokerPlay.

Based on indicators, another two backdoors were uncovered. According to the compilation date, they were created on October 21, 2019; one of them was also uploaded to VirusTotal from Malaysia only in May 2020. This malware belongs to the BACKSPACE family, which has been used by APT30 since 2005.

In addition to known Trojans, two previously unknown malicious programs were discovered in the group's arsenal. One of them is the RHttpCtrl backdoor, which is an x86 executable PE file.

The malware starts off by trying to extract the value of the *random* key of the registry branch HKCU\Software\HttpDiv. If that does not work, the WinAPI function GetSystemTimeAsFileTime provides the system time, which is then used as the seed for random number generation. The random number is saved in the registry and used later.

A GET request to hxxp://www.kabadefender.com/plugins/r.exe gives the malware the legitimate unpacker WinRAR (or at least its CLI component). The malware then takes a fingerprint of the system based on the computer name, IP address, and operating system version. This information is sent by POST request to hxxp://www.kabadefender.com/clntsignin.php. The researchers note that the Trojan is still in its development stage, since some commands are not available.

The second malicious program discovered by the experts was named RCtrl. It is an executable PE file for x86, which was developed using the MFC library and packed with UPX.

First, a data buffer of around 200 bytes is created. This buffer acts as a configuration file.

The malware uses single-byte XOR with 0x23 to decrypt the address of the attacker's main C&C server: 103.233.10\.152. Connection with the server (on TCP port 4433) is checked. If the connection is unsuccessful, the malware uses additional data to obtain a working server address.

After obtaining a working C&C IP address, the malware reconnects to the server and waits for the string Jo*Po*Hello. This string is encrypted in the body of the malware (single-byte XOR with 0x24). When the string is received, the malware creates a system fingerprint based on the OS version, IP address, CPU manufacturer and clock rate, and disk size. The collected data is encrypted with a unique algorithm based on circular shifts and XOR (more specifically: leftward circular shift by 4 + 3 = 7 bits and XOR with 0x23) and sent to the C&C server.

A separate thread is then created to send the same data buffer to the server every 30 seconds. Then control passes to the command handling function, which decrypts the input and extracts the command number.

APT30 is a Chinese cyberespionage group (also known as Override Panda and BRONZE GENEVA) that primarily attacks government entities in South and South-East Asia (India, Thailand, Malaysia, etc.) for the purposes of cyberespionage; their tools have been developing since at least 2005 .

Data leaks

- In February, the researcher Troy Hunt discovered an unprotected Elastic search database called "db8151dd" containing over 90 GB of data, including names, email addresses, phone numbers, physical addresses, social media profiles, and job titles of more than 22 million people. The researcher tried to identify the company that owned this database. In May, he concluded that it was the Cyprus-based company Covve, which confirmed the leak.
- In early May, the researcher Justin Paine discovered an open Elasticsearch database belonging to the Thai telecommunications company Advanced Info Service (AIS). The database contained over 8 million documents. Access to it was restricted on May 22; threat actors did not seem to detect this database during that time and a potential data leak was avoided.
- In late May, Nippon Telegraph & Telephone (NTT), Japan's largeset telecommunications company, reported a data leak. According to the victim company, hackers penetrated its network and later sold data on 621 customers. The attack took place between May 7 and 11.
  Hackers reached Active Directory, from where they gained access to cloud servers in various countries.
- Shiny Hunters hackers published data on 15 million users of Tokopedia, Indonesia's largest online store.
  They later put up for sale the company's entire database containing 91 million records, asking $5,000 for it.
  After this case, the threat group put up for sale the data of the following companies: the Zoosk app, Chatbooks service, the South Korean resource SocialShare, delivery service Home Chef, online shop Minted, online news resource Chronicle of Higher Education, medical news resource Mindful, Indonesian online store Bhinneka, and the US newspaper StarTribune.
- A hacker with the nickname KingNull made public the database of Daniel's Hosting (DH), one of the biggest hosting services on the Darknet.
  DH was hacked in the spring of 2020. At the time, unknown threat actors gained access to DH's back end and deleted all databases related to the hosting service as well as its owner's account. The hosting service's developer Daniel Winzen wrote in a blog that it was too late when he discovered the hack: there was nothing to be saved, since DH deliberately did not have backups. As a result, Winzen shut down his service and urged its users to move their websites elsewhere. A total of about 7,600 websites (about a third of all onion resources) went offline due to DH's closure.
  It is now apparent that in May 2020 not only were the databases deleted, they were also stolen. Someone with the nickname KingNull uploaded a copy of the stolen database to a file hosting resource and notified ZDnet about it. The leaked data includes 3,671 email addresses, 7,205 account passwords, and 8,580 private keys for onion domains.
- In June, a data breach that occurred at the South African bank Postbank in 2018–2019 was discovered. The bank lost $3.2 millon because of the incident and had to reissue 12 million cards, which also entailed considerable expense.
- EasyJet reported a breach of data of about nine million customers as well as data on 2,208 bank cards. The airline says that the information was obtained by threat actors as result of a sophisticated cyberattack. The breached data included email address and flight information. No technical details of the attack have been revealed. Group-IB specialists have not found this data on sale on underground forums.
- In early April, the hospitality company Marriott reported another data leak. This was not the first time the company had experienced such problems. The new incident resulted in the leak of 5.2 million records with customers' personal data: names, addresses, phone numbers, email addresses, loyalty programs, dates of birth, gender, and language.

- In June, the computer game Stalker Online was breached, which resulted in over 1 million user passwords being leaked; the passwords were MD5 hashed and salted, which means they can be recovered.
- In June, over 20 million records were leaked from the portal of the Department of Household Registration under Taiwan's Ministry of Interior. The leaked database was found on the Darknet. The seller was a threat actor called Toogod and the archive included 3.5 GB of data with user names, addresses, IDs, dates of birth and gender.